

Laboratorios Owasp top 10

Fabian Camilo Garzón Cative

Universidad de Cundinamarca

Extensión Chía

Línea de profundización III

Junio 2023

Tabla de contenidos

Introducción.....	3
Objetivos	3
Objetivo general	3
Objetivos específicos	4
Insecure direct object references	5
Fallos criptográficos.....	19
Archivo en una web y SQLI	32
Archivos ocultos en sitio web	32
SQL Injection en POST.....	36
Conclusiones	52

Introducción

El siguiente trabajo se realizó con el objetivo de aprender diferentes prácticas de seguridad informática y se encuentra dividido en tres partes, la primera parte es del inadecuado control de acceso para ello se utilizarán las siguientes aplicaciones dentro de Kali Linux, Burpsuite y un navegador, en este caso Mozilla Firefox. El laboratorio se encuentra en el sitio PortSwigger y es de libre acceso, únicamente se debe tener una cuenta registrada para poder tener acceso a este.

La segunda parte trata de fallos criptográficos, para este laboratorio se utilizará Kali Linux, un navegador y la aplicación hash-identifier; en esta parte se busca cifrar una contraseña para posteriormente descifrarla usando las aplicaciones anteriormente mencionadas y ver lo sencillo que es hacerlo al usar protocolos de hasheo obsoletos o muy antiguos.

La tercer y última parte consta de dos partes, la primera busca identificar archivos ocultos en una página web y la segunda sobre inyección de código SQL, para las dos prácticas se necesita Kali Linux y Metasploitable, aquí se busca acceder a archivos confidenciales a través de la URL y cómo ingresar como un usuario administrador a un sistema de seguridad baja y media.

Objetivos

Objetivo general

- Realizar diferentes prácticas para hallar vulnerabilidades usando el OWASP top 10.

Objetivos específicos

- Preparar el Kali Linux para las prácticas.
- Configurar el proxy con el Burpsuite.
- Descargar los certificados para evitar problemas con la navegación.
- Tener una conversación con el chat de PortSwigger.
- Cifrar una contraseña con el método MD5.
- Abrir hash-identifier.
- Hacer ataque diccionario para descifrar la contraseña.
- Preparar Metasploitable.
- Configurar la base de datos de Metasploitable.
- Ejecutar comandos de SQLI para acceder al aplicativo web.

Insecure direct object references

Como primer paso se debe ejecutar el Burpsuite dentro del Kali Linux, posteriormente ir al apartado de proxy y configuración de proxy.

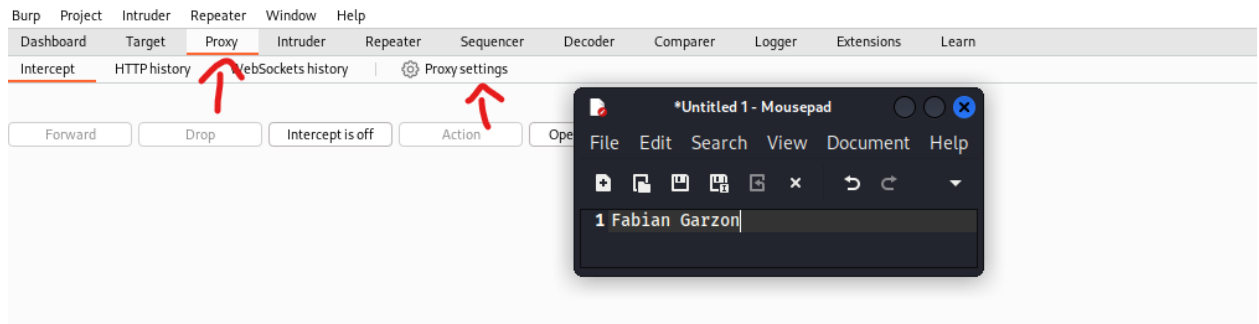


Imagen 1. Ingreso a configuración proxy en Burpsuite

A continuación, se desplegará una ventana con la configuración del proxy del burpsuite, allí veremos una dirección IP y el puerto por donde se está escuchando. Después de ver la dirección IP y el puerto es momento de hacerlo en el navegador configurando el proxy, para poder configurarlo se debe ir a opciones del navegador y allí buscar proxy, y configurarlo de la siguiente manera para este laboratorio.

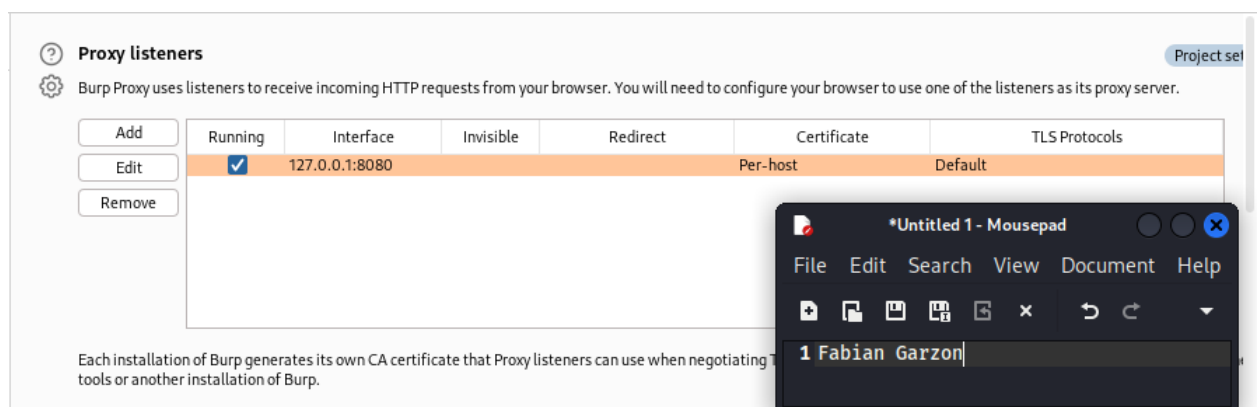


Imagen 2. Configuración proxy en Burpsuite

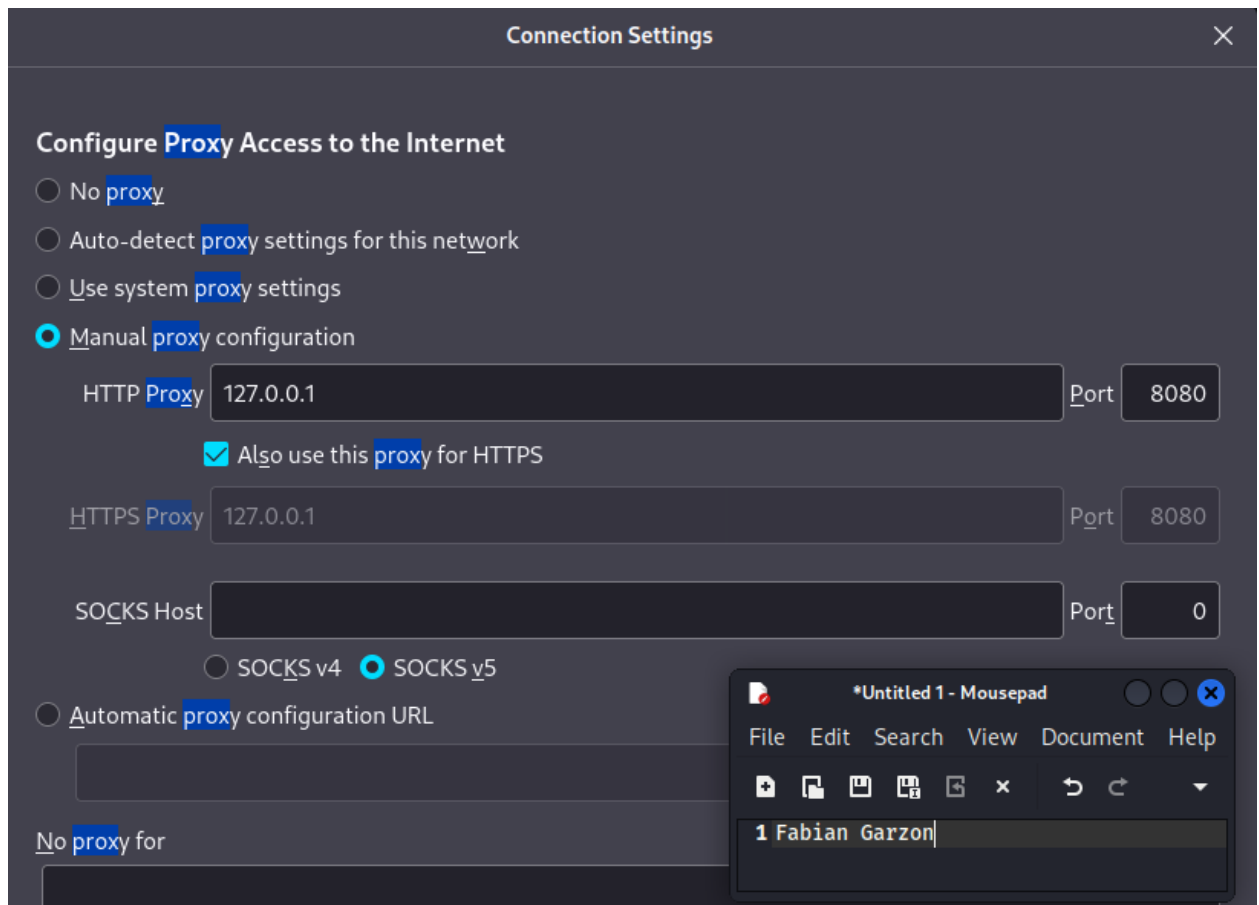


Imagen 3. Configuración proxy Mozilla Firefox

Luego de hacer esto se deben descargar los certificados para la navegación con el proxy de Burpsuite, para ello hay que dirigirse a la configuración de proxy en Burpsuite y dar clic en “Import/Export CA Certificate”, seleccionar la primera opción en la siguiente ventana que aparezca, dar clic en siguiente y seleccionar dónde lo queremos guardar, asignarle un nombre por último verificar que el certificado se haya guardado.

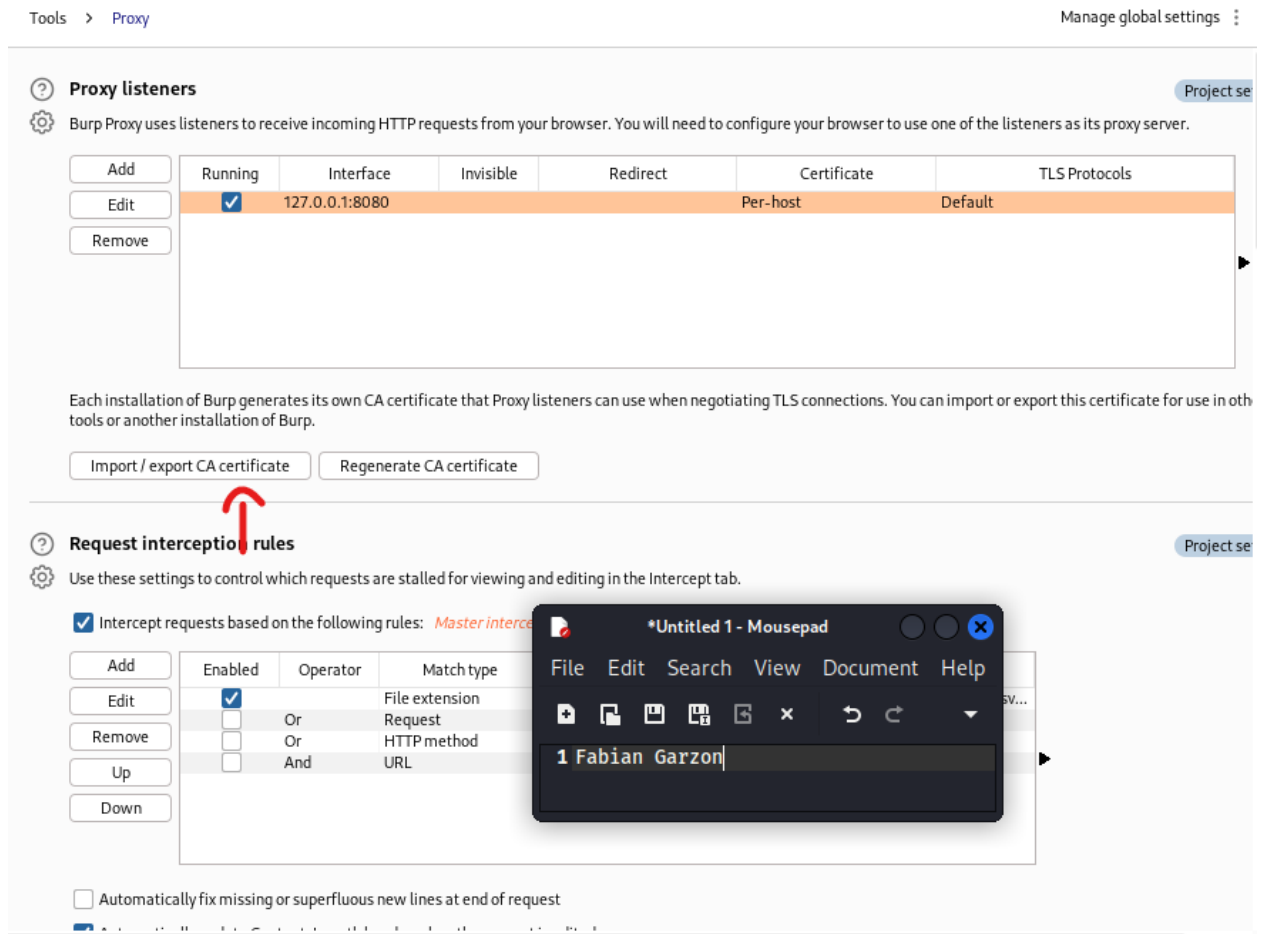


Imagen 4. Importar o exportar Certificado CA

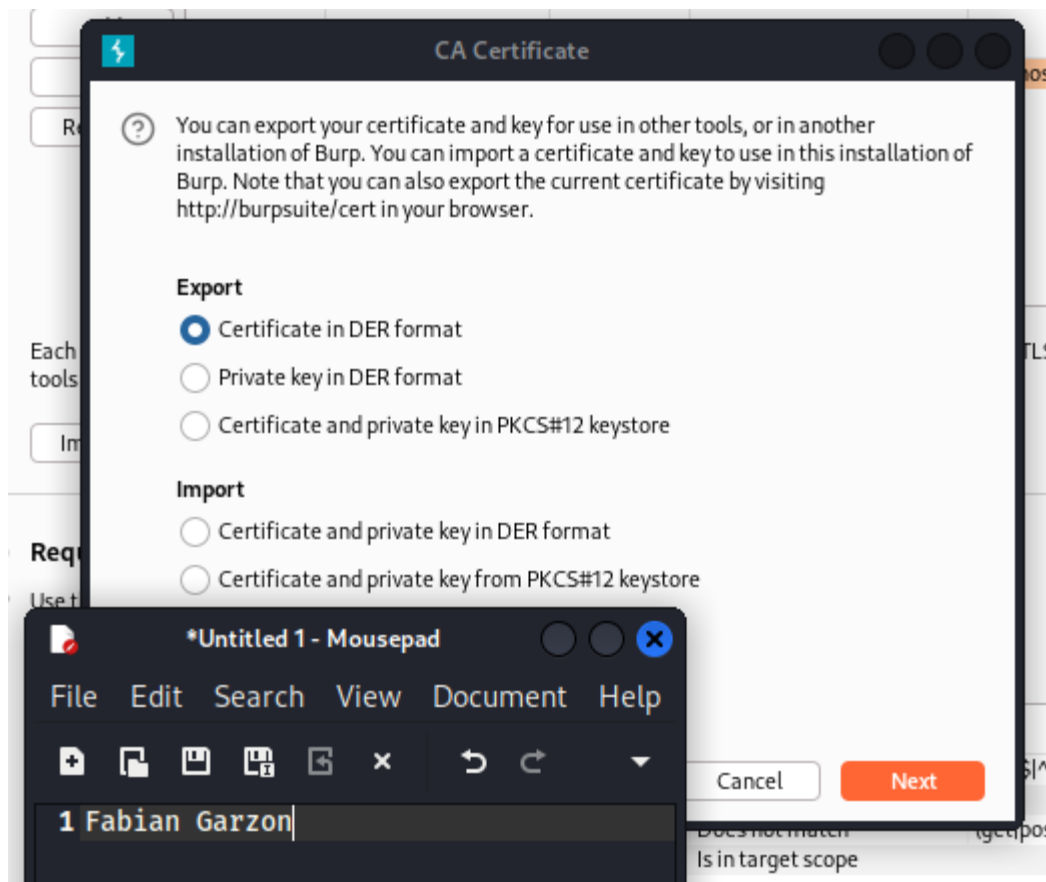


Imagen 5. Seleccionar Certificado en formato DER

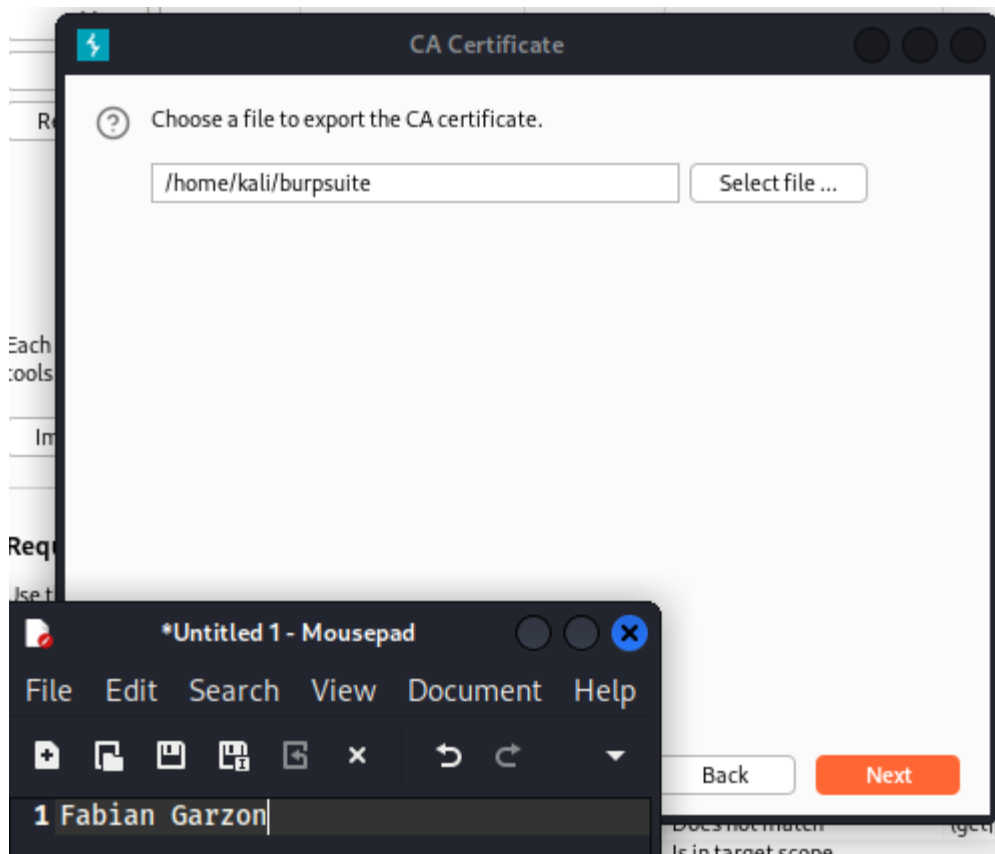


Imagen 6. Asignación de directorio y nombre para guardar el certificado

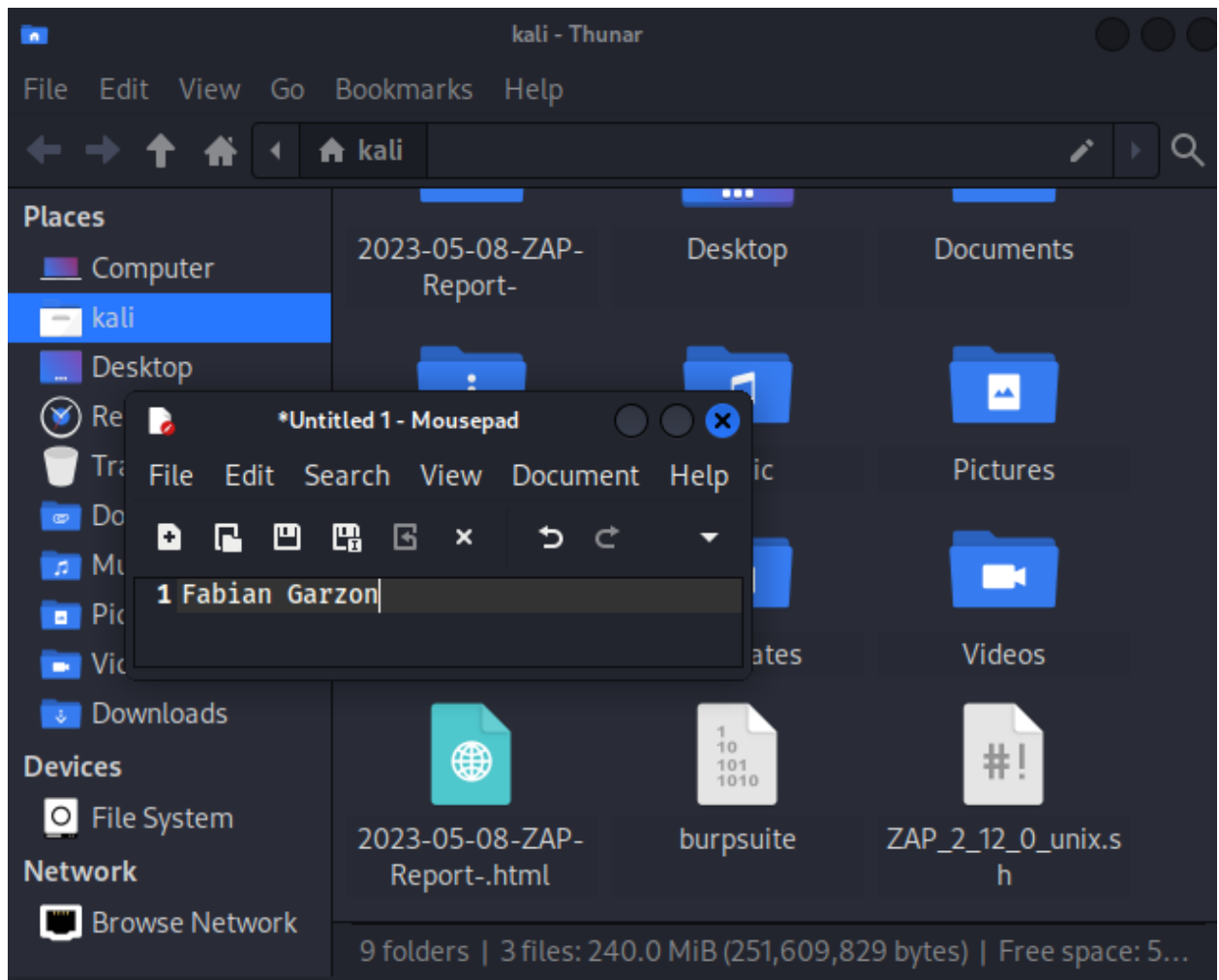


Imagen 7. Verificación del certificado

Ahora en el navegador se busca “certificates” y se selecciona la opción de ver los certificados o “view certificates”. Allí dar clic en importar y seleccionar el certificado que se descargó anteriormente, en caso de que no aparezca, cambiar a “all files”. Al seleccionarlo aparece una ventana dónde se pregunta si confía en los autores de ese certificado, se van a marcar las dos casillas y luego ok. Para verificar que el certificado fue importado con éxito se busca el certificado con el nombre PortSwigger CA, y buscar la siguiente URL <http://burp/> que direcciona a la página que se muestra en la imagen 12.

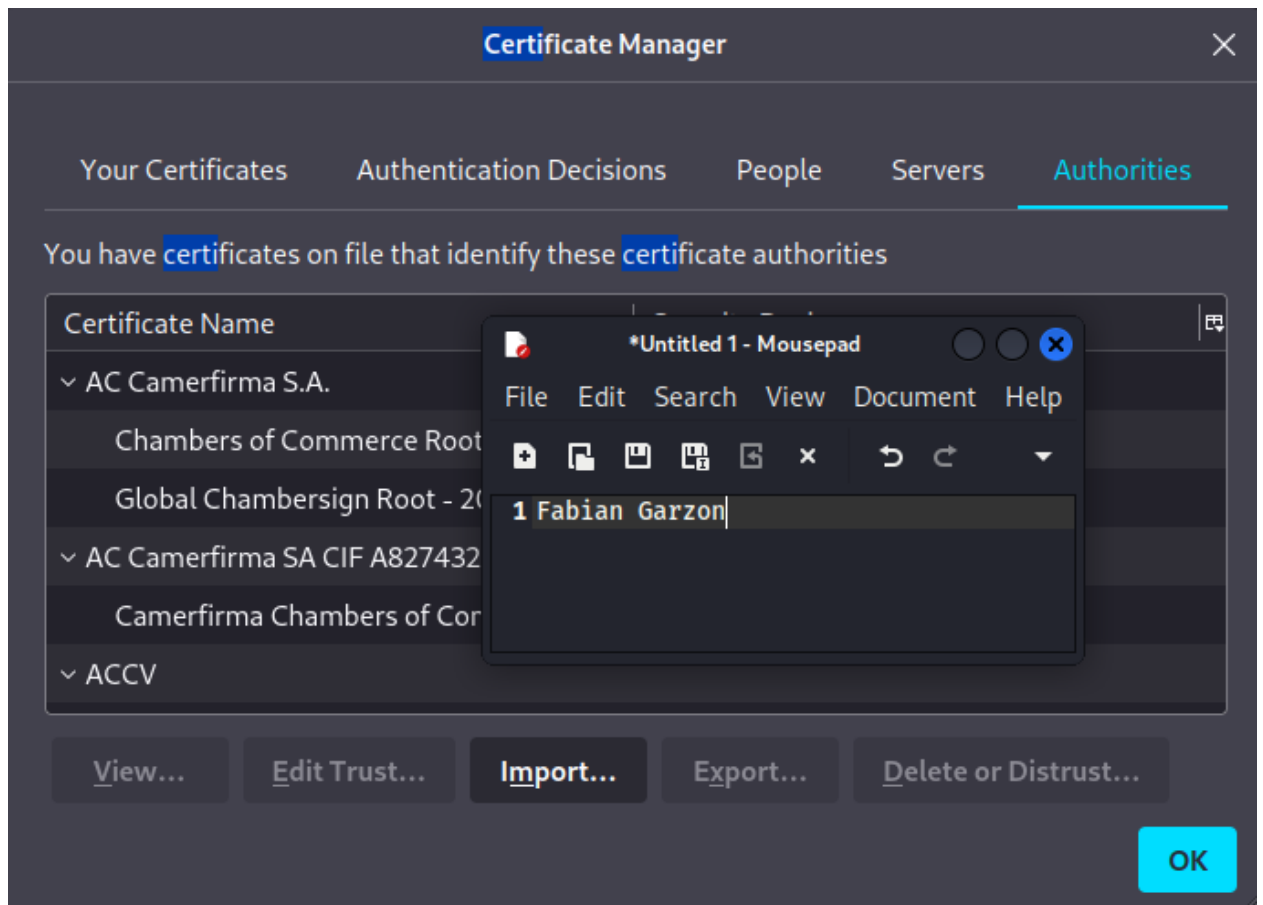


Imagen 8. Ventana view certificates en Mozilla Firefox

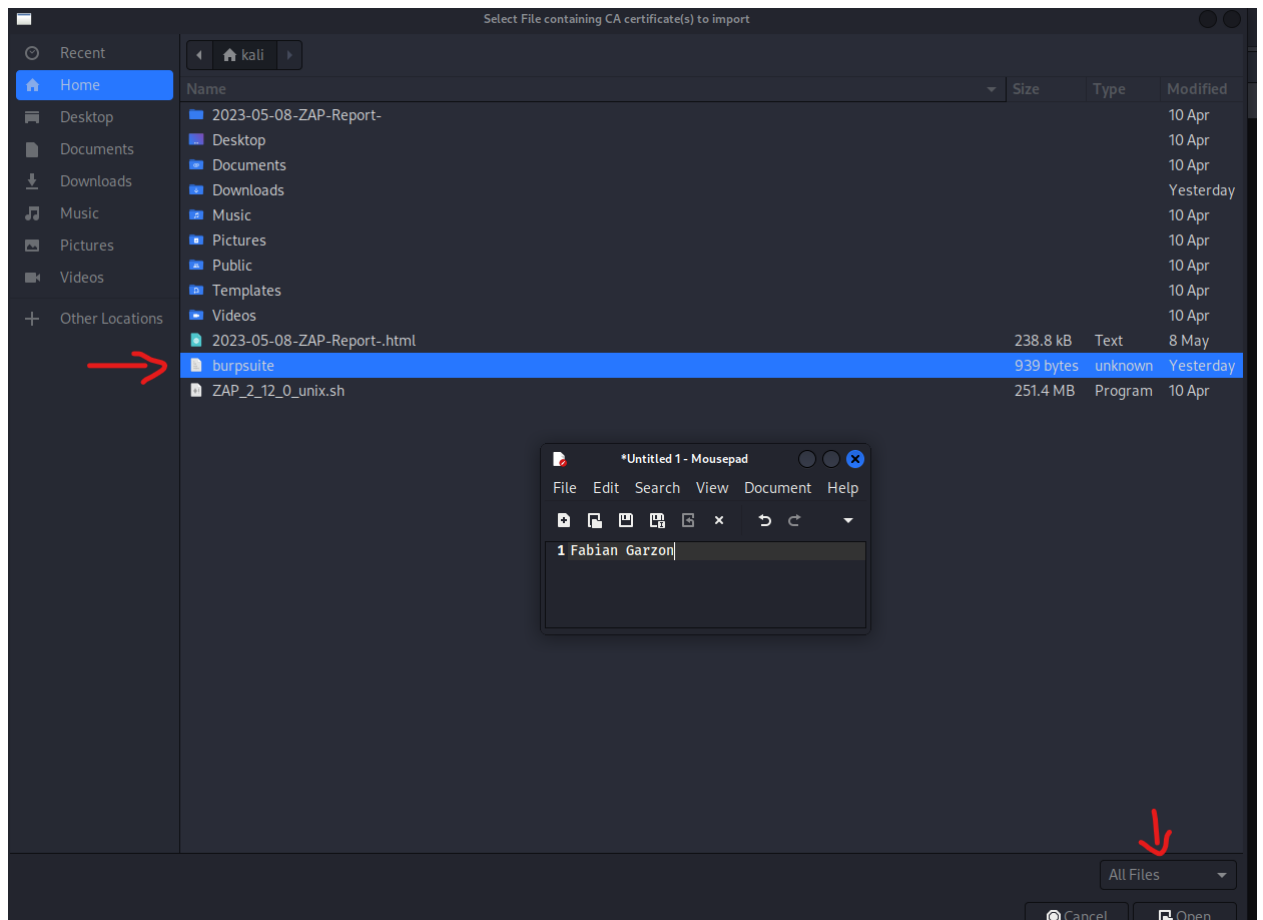


Imagen 9. Selección del certificado

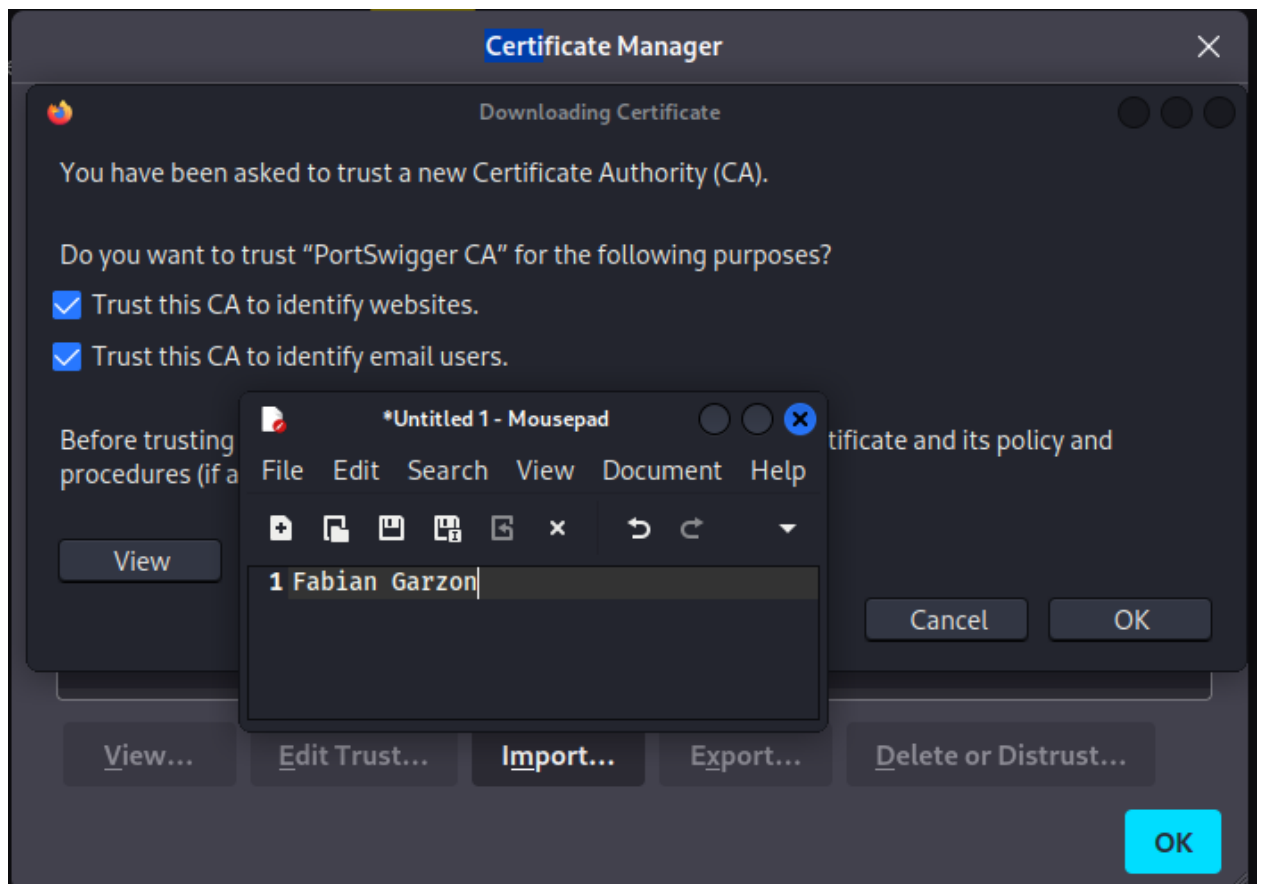


Imagen 10. Aceptar que se confía en los autores del certificado

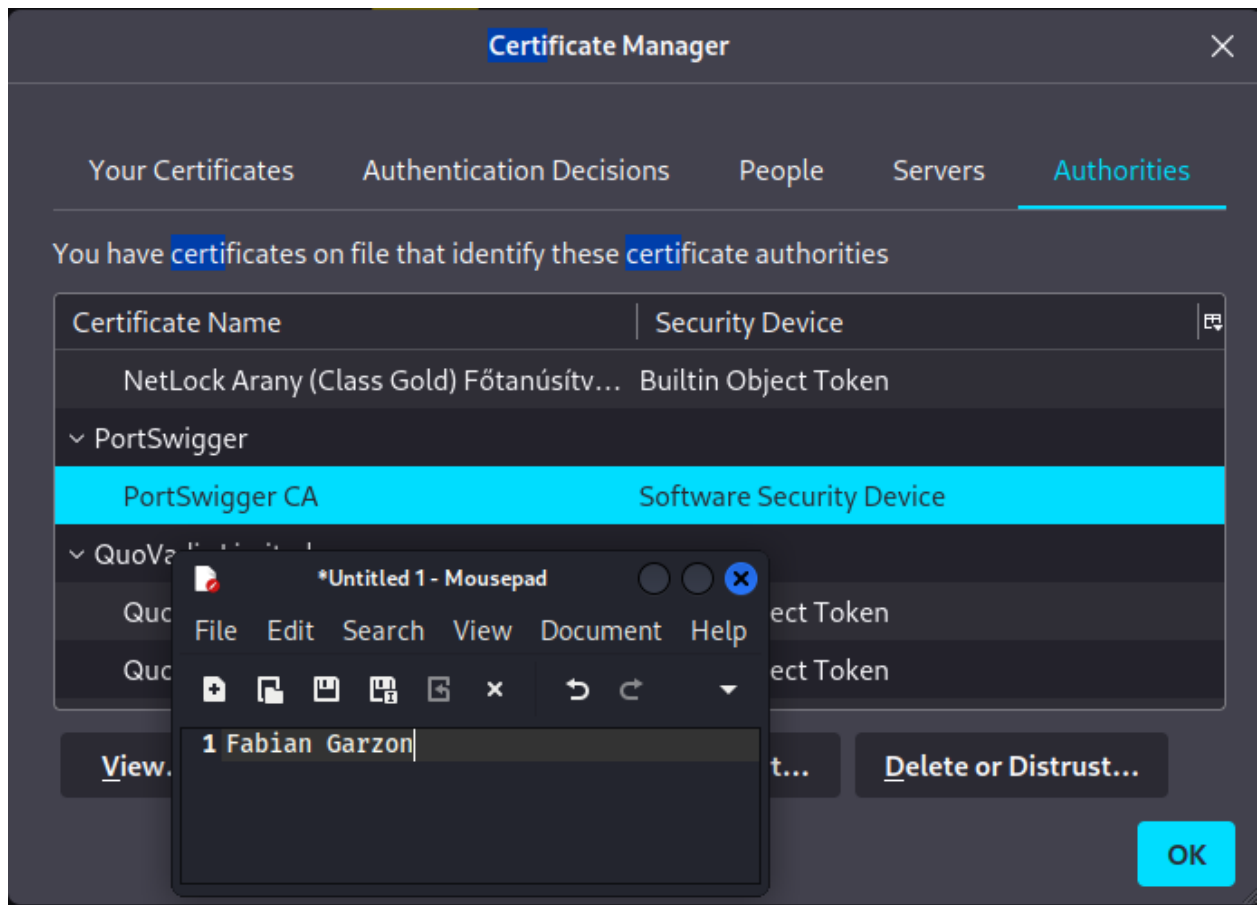


Imagen 11. Verificación del certificado en la ventana View Certificates

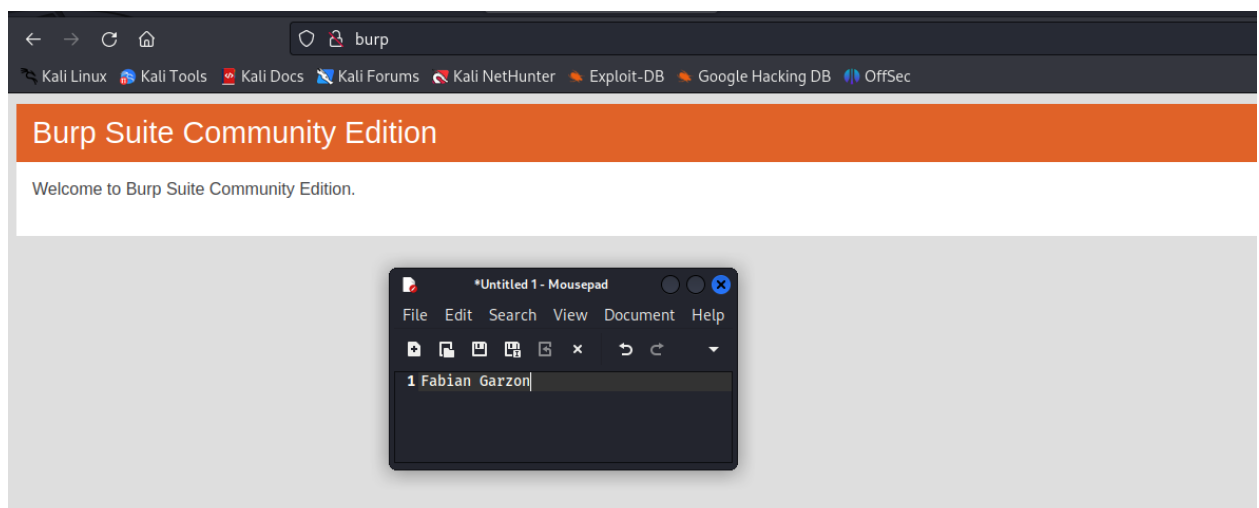


Imagen 12. Verificación del certificado a través de la página burp

Dar clic en Acces the lab, en la página de PortSwigger Lab: Insecure direct object references, esto dará un direccionamiento a otra página, donde se dará clic en Live Chat y se mostrará una ventana de chat, allí se le envían datos al chat, en este caso fueron dos mensajes, el primero con un mensaje de “holi bot” y el siguiente “no hablo ingles bro”. Posterior a ello se dará clic en View transcript, y se descargará un archivo llamado “2.txt”.

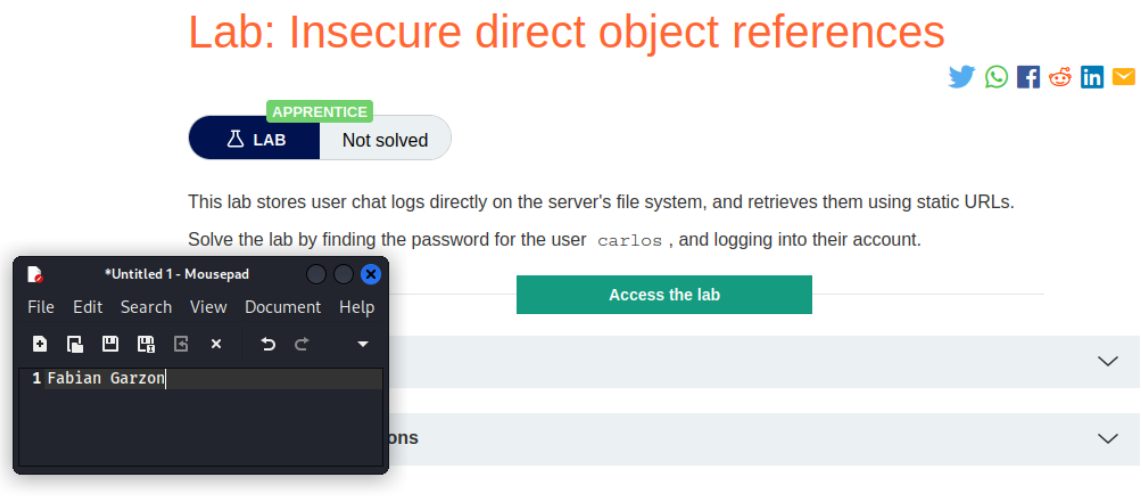


Imagen 13. Acceder al laboratorio

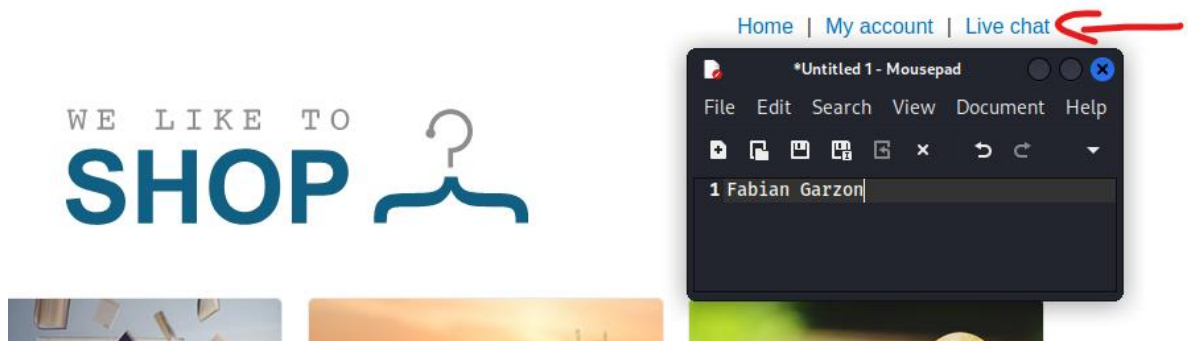


Imagen 14. Acceder al Live Chat

Live chat

CONNECTED: -- Now chatting with Hal Pline --

You: holi bot

Hal Pline: I can hear you, there is no need to shout

You: no hablo ingles bro

Hal Pline: I'll look that up when my nail polish has dried.

[typing...]

DISCONNECTED: -- Chat has ended --

Your message:

Send

View transcript

Imagen 15. Conversación en el chat

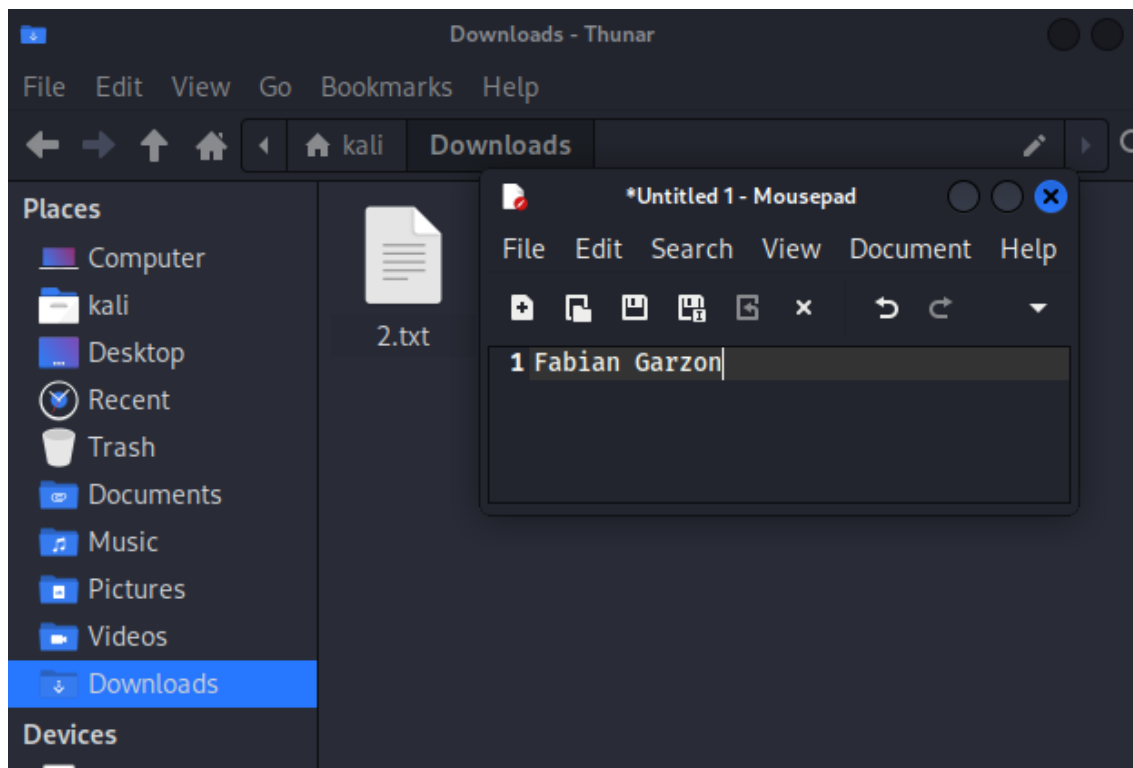


Imagen 16. Conversación descargada desde la opción View transcript

Con el archivo descargado ahora hay que dirigirse al burpsuite y buscar por el método GET la descarga del archivo “2.txt”, al encontrarla dar clic y verificar la conversación que se tuvo, luego oprimir la secuencia “Control + R”, al hacer esta combinación se hará una repetición de ese GET en la ventana de “Repeater” en burpsuite. Para finalizar en ese repeat cambiar el 2 por un 1 y luego dar clic en send, allí se mostrará la contraseña del usuario.

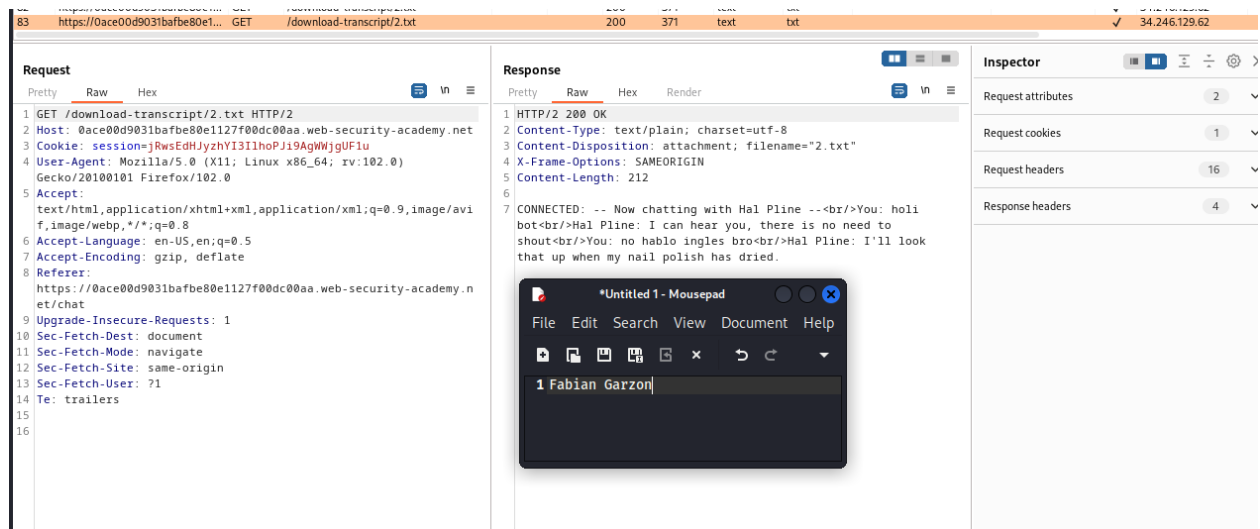


Imagen 17. Intercepción del método GET en la descarga del archivo “2.txt”

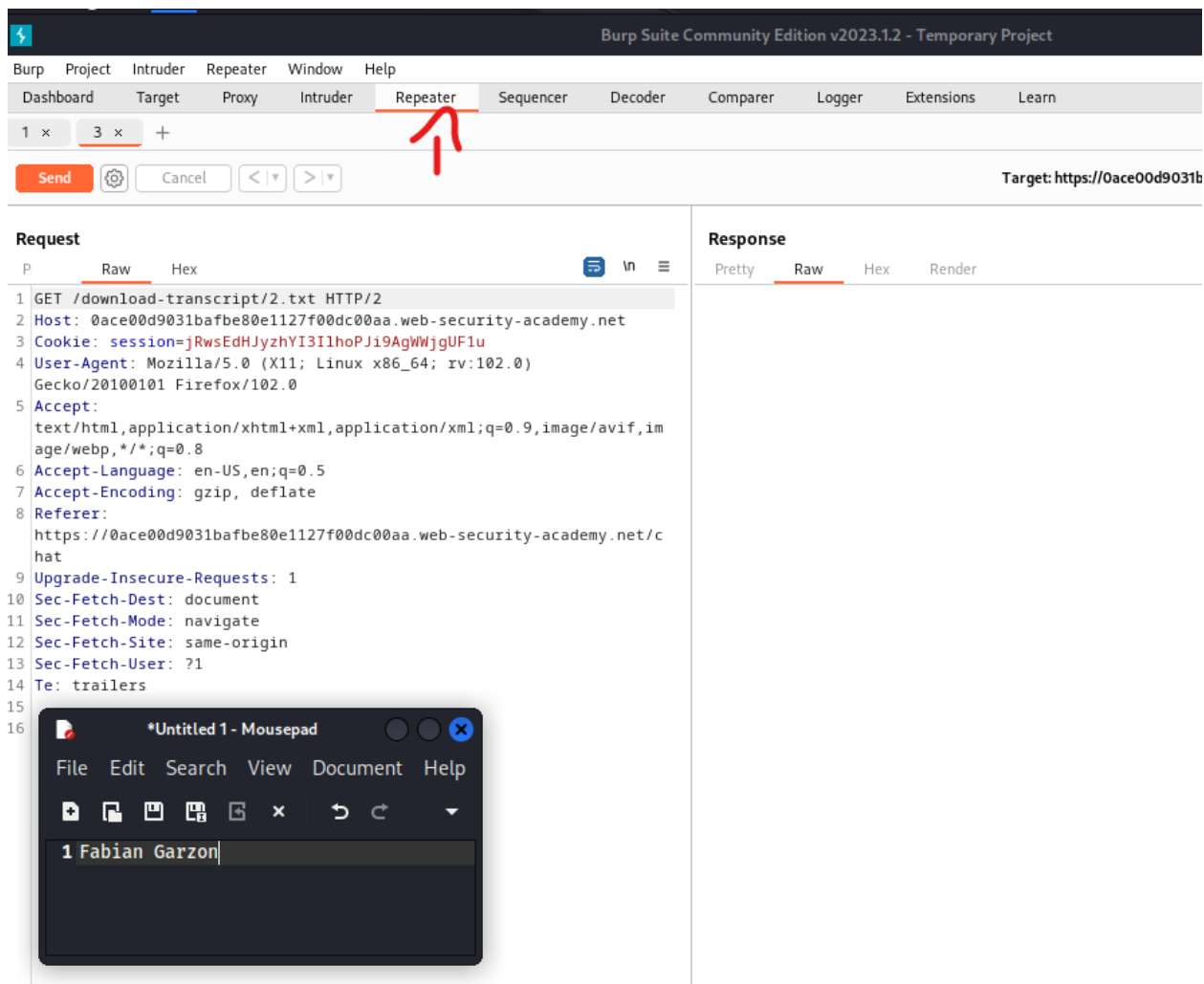


Imagen 18. Repeater del método GET del archivo “2.txt”

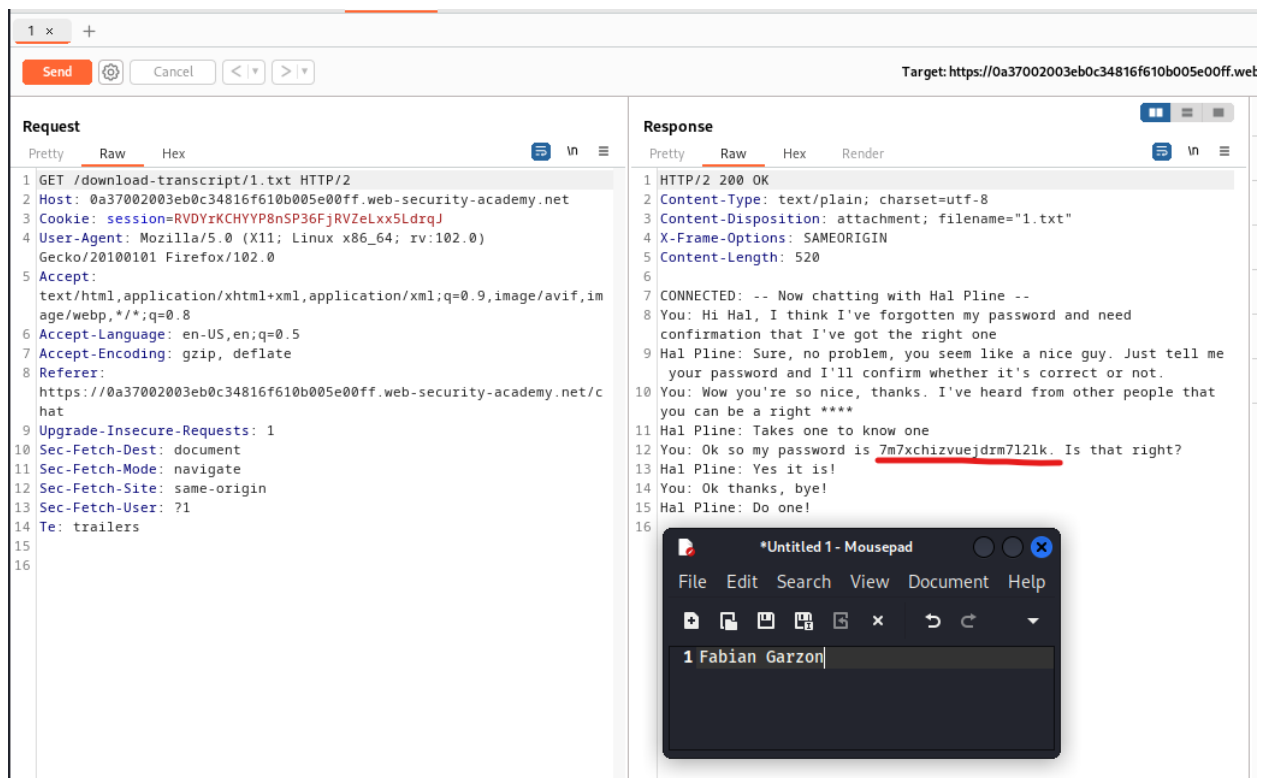


Imagen 19. Cambio del 2 por 1 y send, se muestra la contraseña del usuario

Fallos criptográficos

Para iniciar el laboratorio se debe iniciar Kali Linux y en el navegador buscar “emn178” e ingresar al enlace que dice MV5, este es un protocolo de criptografía que fue muy usado y por ende ya es sencillo desencriptar, a menos que se realice una concatenación para que el atacante tenga un poco más difícil descifrar la contraseña.

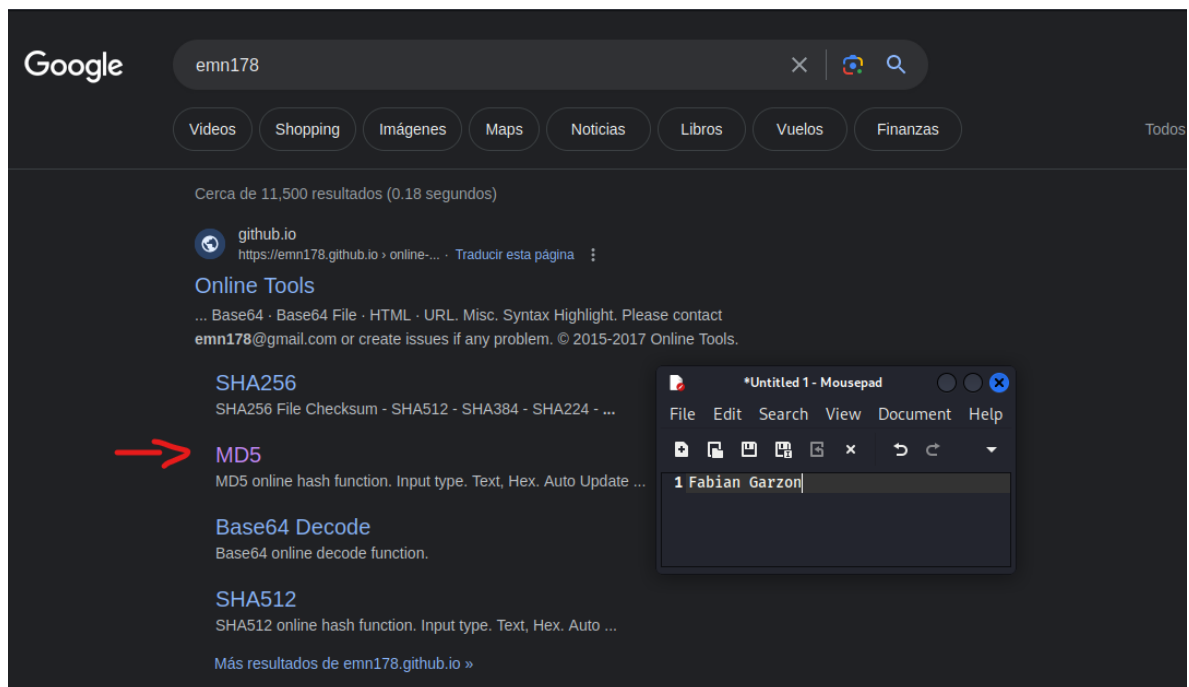


Imagen 20. Búsqueda de emn178

A continuación, colocar una contraseña en el cuadro de texto de MD5, al colocar cualquier carácter o palabra en la parte de abajo aparece el hasheo o encriptación de dicha palabra, en este caso se utilizó la palabra “password”.



Imagen 21. Hasheo de la palabra password

Ahora se crea un documento de texto desde la consola de Kali, con la siguiente línea de comandos, `sudo su`, `cd Desktop`, `nano contraseña.txt`, el `sudo su` es para acceder como usuario root, `cd Desktop` se utiliza para ir al escritorio de Kali, y por último `nano` para crear un documento y se coloca el nombre con la respectiva extensión. Allí se pega el hash de password creado anteriormente y luego guardar.

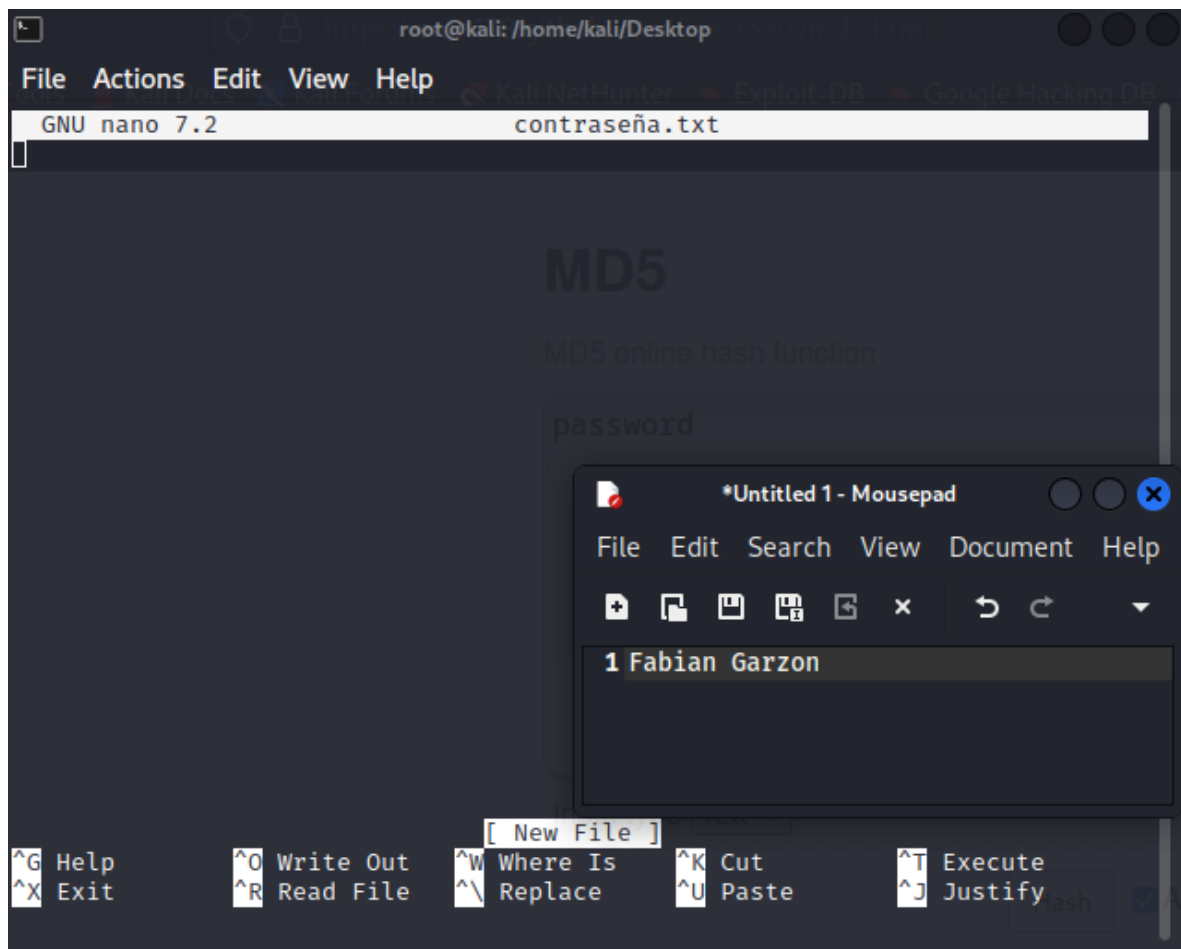


Imagen 22. Nano contraseña.txt

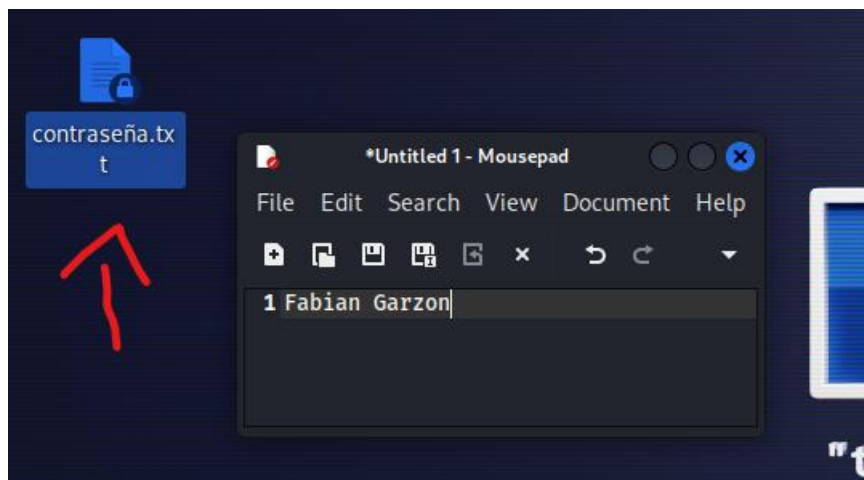


Imagen 23. Archivo de texto creado en el escritorio

Se ejecuta el comando `cat contraseña.txt` para ver el contenido del archivo.

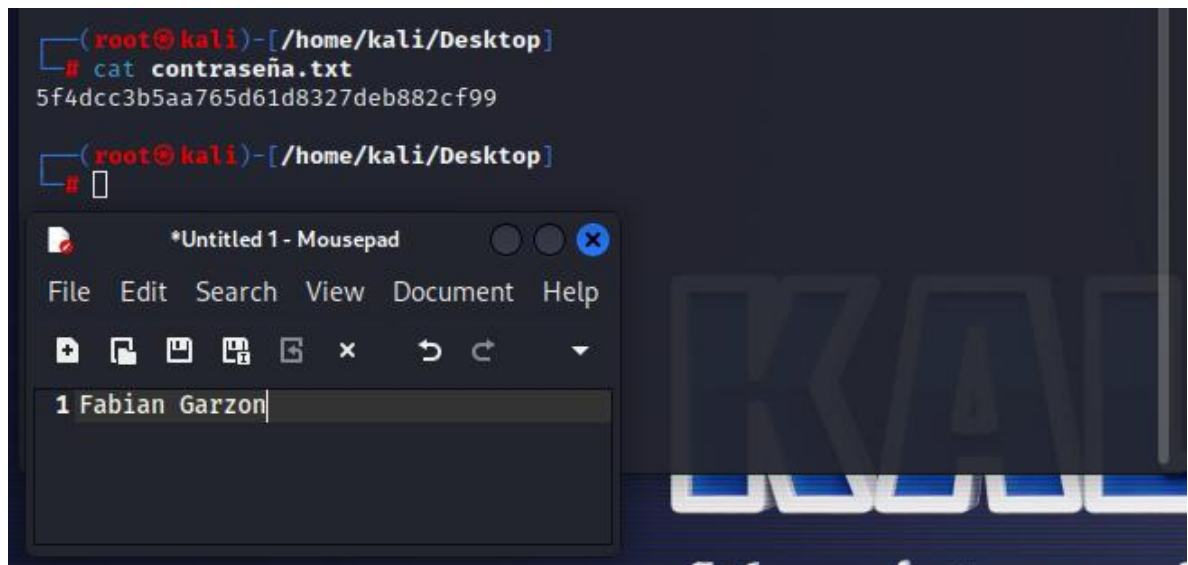


Imagen 24. Ejecución comando cat

Ahora vamos a usar una aplicación de Kali llamada hash-identifier, esta aplicación sirve para saber qué tipo de protocolo de criptografía está siendo usado en el hash.

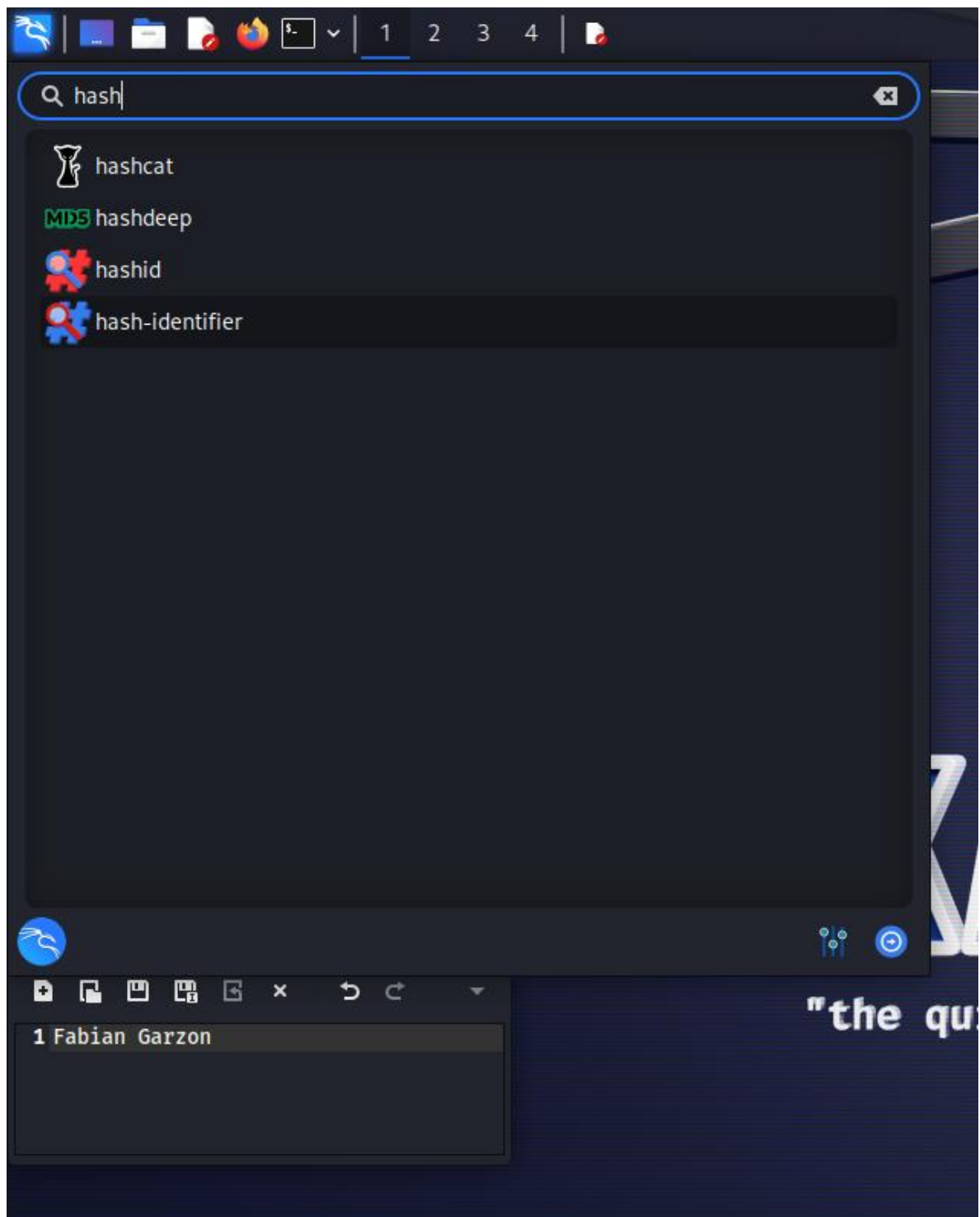


Imagen 25. Búsqueda Hash-identifier

Se abre una ventana dónde pide un hash, en esta parte se va a pegar el hash de password que fue creado, esto arrojará una ventana con el tipo de cifrado que se utilizó para esta contraseña.

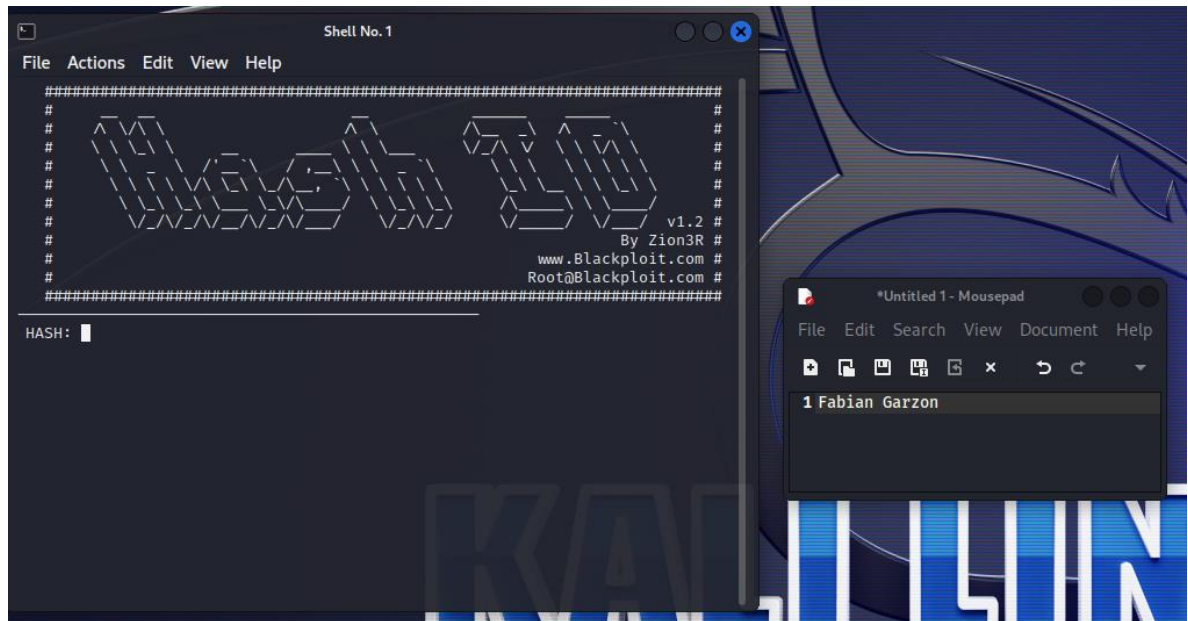


Imagen 26. Ventana de Hash-identifier

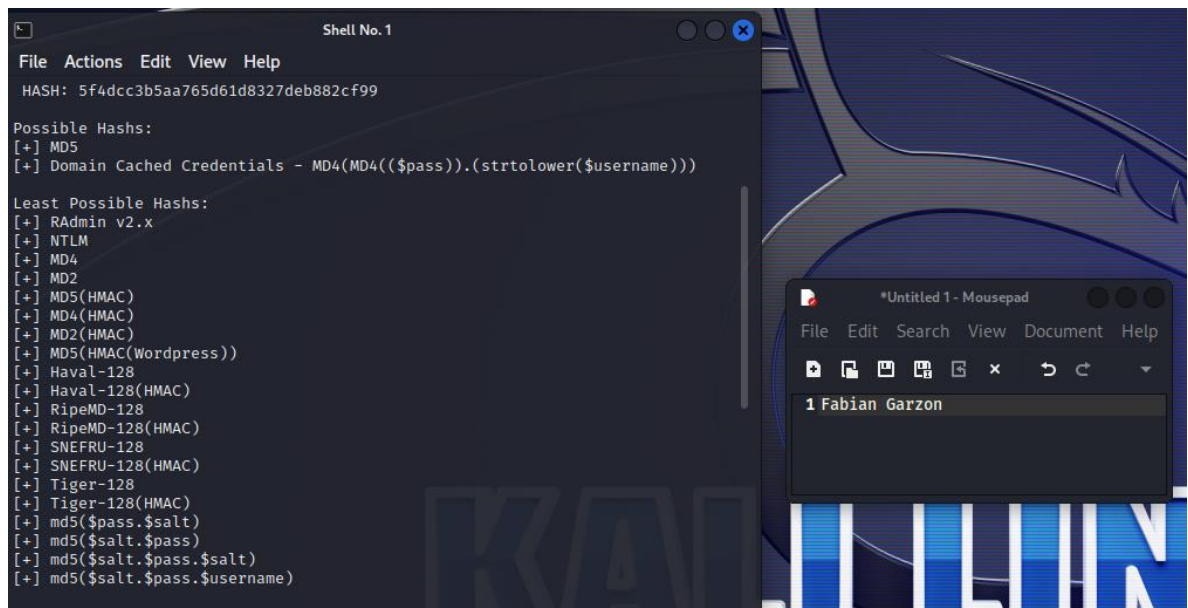
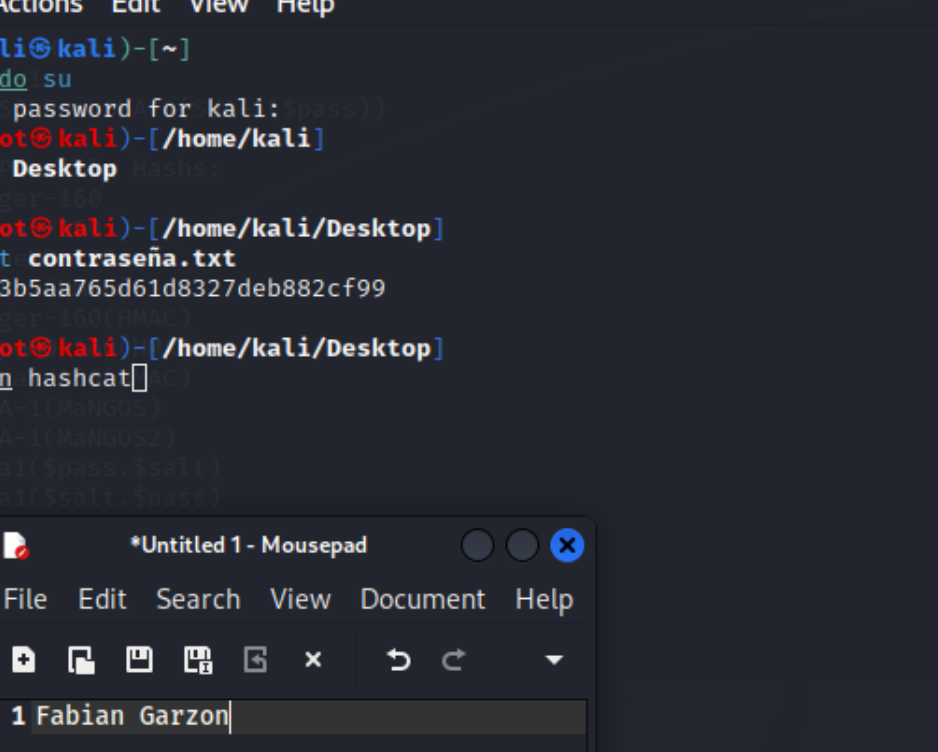


Imagen 27. Hash MD5

Se ejecuta el comando `man hashcat`, esto abrirá una ventana que despliega todos los tipos de hash que se pueden descriptar.



The image shows a Kali Linux terminal window with the following commands and output:

```
root@kali: /home/kali/Desktop
File Actions Edit View Help
(kali㉿kali)-[~]
$ sudo su
[sudo] password for kali:(pass)
(root㉿kali)-[/home/kali]
# cd Desktop
[-] Tiger-160
(root㉿kali)-[/home/kali/Desktop]
# cat contraseña.txt
5f4dcc3b5aa765d61d8327deb882cf99
[-] Tiger-160(HMAC)
(root㉿kali)-[/home/kali/Desktop]
# Man hashcat
[-] SHA-1(MaNGOs)
[-] SHA-1(MaNGOs2)
[-] sha1($pass,$salt)
[-] sha1($salt,$pass)
```

Overlaid on the terminal is a Mousepad text editor window titled "Untitled 1 - Mousepad". It has a menu bar with "File", "Edit", "Search", "View", "Document", and "Help". The toolbar includes icons for new, open, save, print, undo, redo, and a dropdown menu. The text area contains the following text:

```
1 Fabian Garzon|
```

Imagen 28. Uso de comando man hashcat

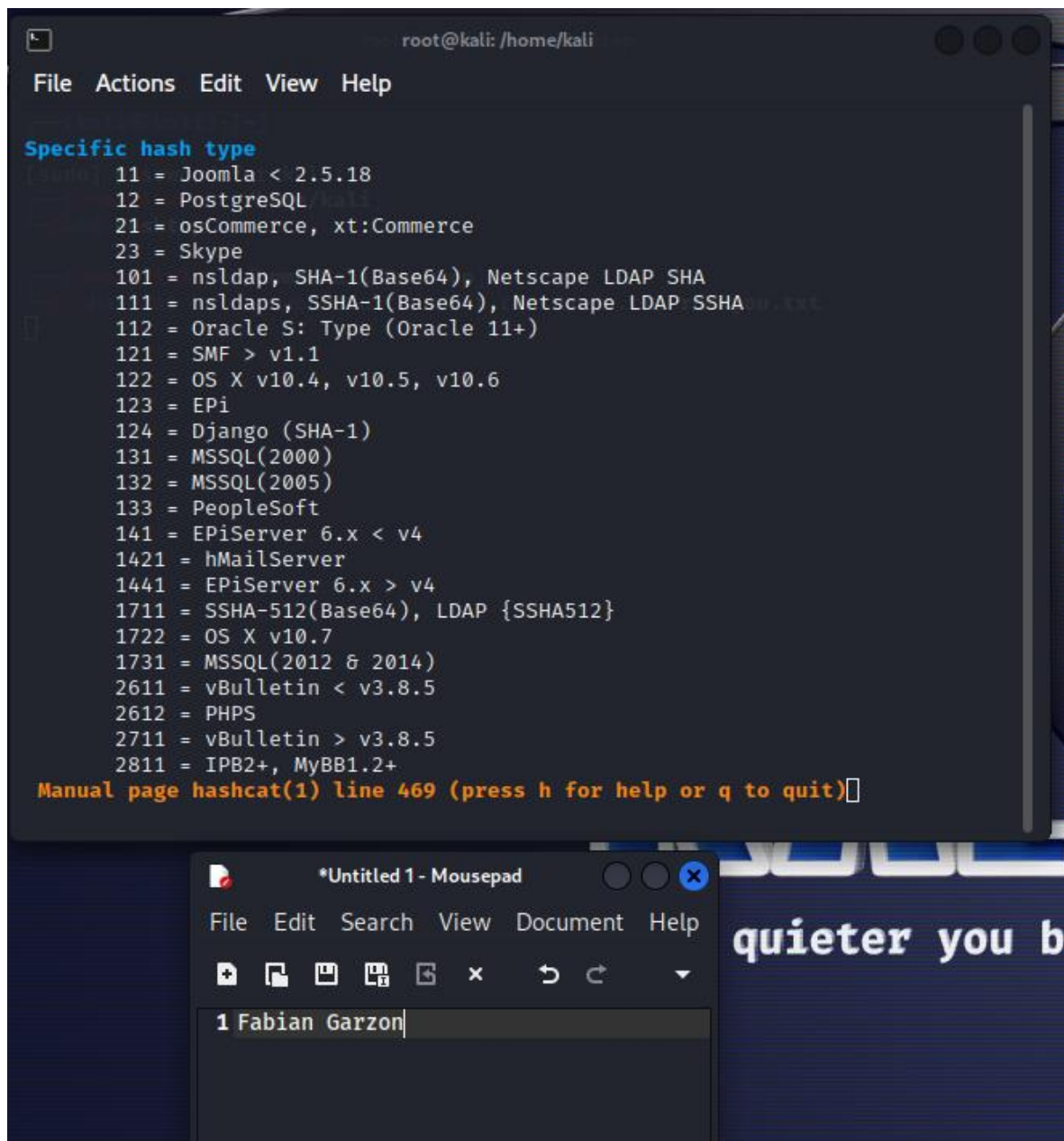


Imagen 29. Ventana con los tipos de hash

Se debe buscar y descargar el documento de texto rockyou, que es como un diccionario, esto facilita el trabajo para descryptar la contraseña.

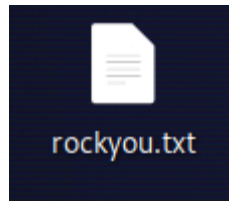


Imagen 30. Rockyou

Ahora se ejecuta el comando `hashcat -m 0 -a 0 resultado.txt contraseña.txt rockyou.txt`

A screenshot of a Kali Linux desktop environment. The background is a dark blue terminal window with a menu bar (File, Actions, Edit, View, Help) and a title bar (root@kali: /home/kali/Desktop). The terminal shows the following commands and output:

```
(kali@kali)-[~]  
$ sudo su  
[sudo] password for kali:  
(root@kali)-[/home/kali]  
# Man hashcat  
Command 'Man' not found, did you mean:  
  command 'dan' from deb emboss  
  command 'pan' from deb pan  
  command 'man' from deb man-db  
Try: apt install <deb name>  
  
(root@kali)-[/home/kali]  
# man hashcat  
  
(root@kali)-[/home/kali]  
# cd Desktop  
  
(root@kali)-[/home/kali/Desktop]  
# hashcat -m 0 -a 0 -o resultado.txt contraseña.txt rockyou.txt
```

In the foreground, there is a window titled '*Untitled 1 - Mousepad' with a menu bar (File, Edit, Search, View, Document, Help) and a toolbar. The text '1 Fabian Garzon' is visible in the editor area. A large, semi-transparent 'KALI' logo is visible in the background of the terminal window.

Imagen 31. Uso del comando

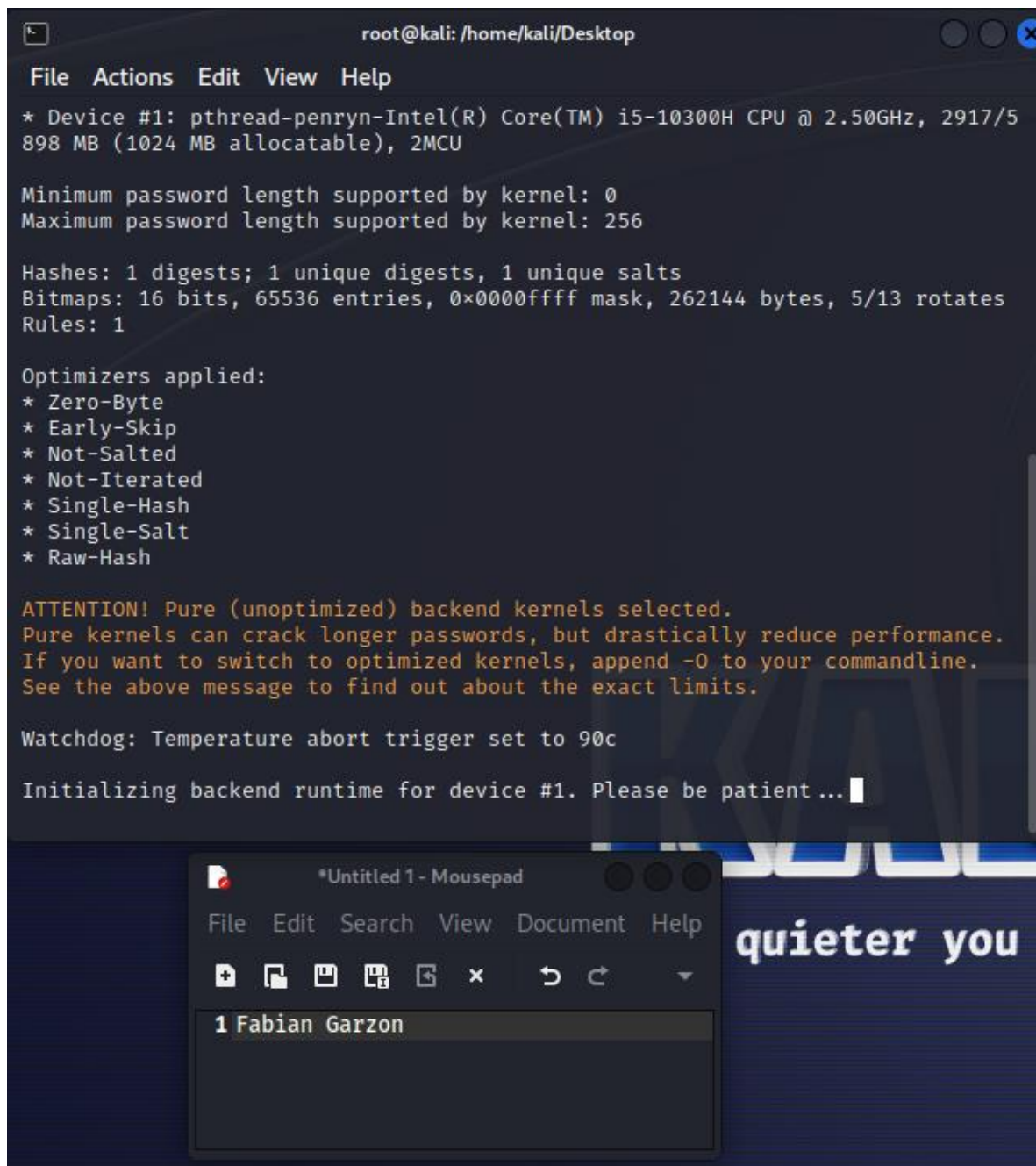


Imagen 32. Ejecución del comando ingresado

Al terminar la ejecución del comando, se crea un nuevo archivo de texto en el escritorio llamado resultado.txt

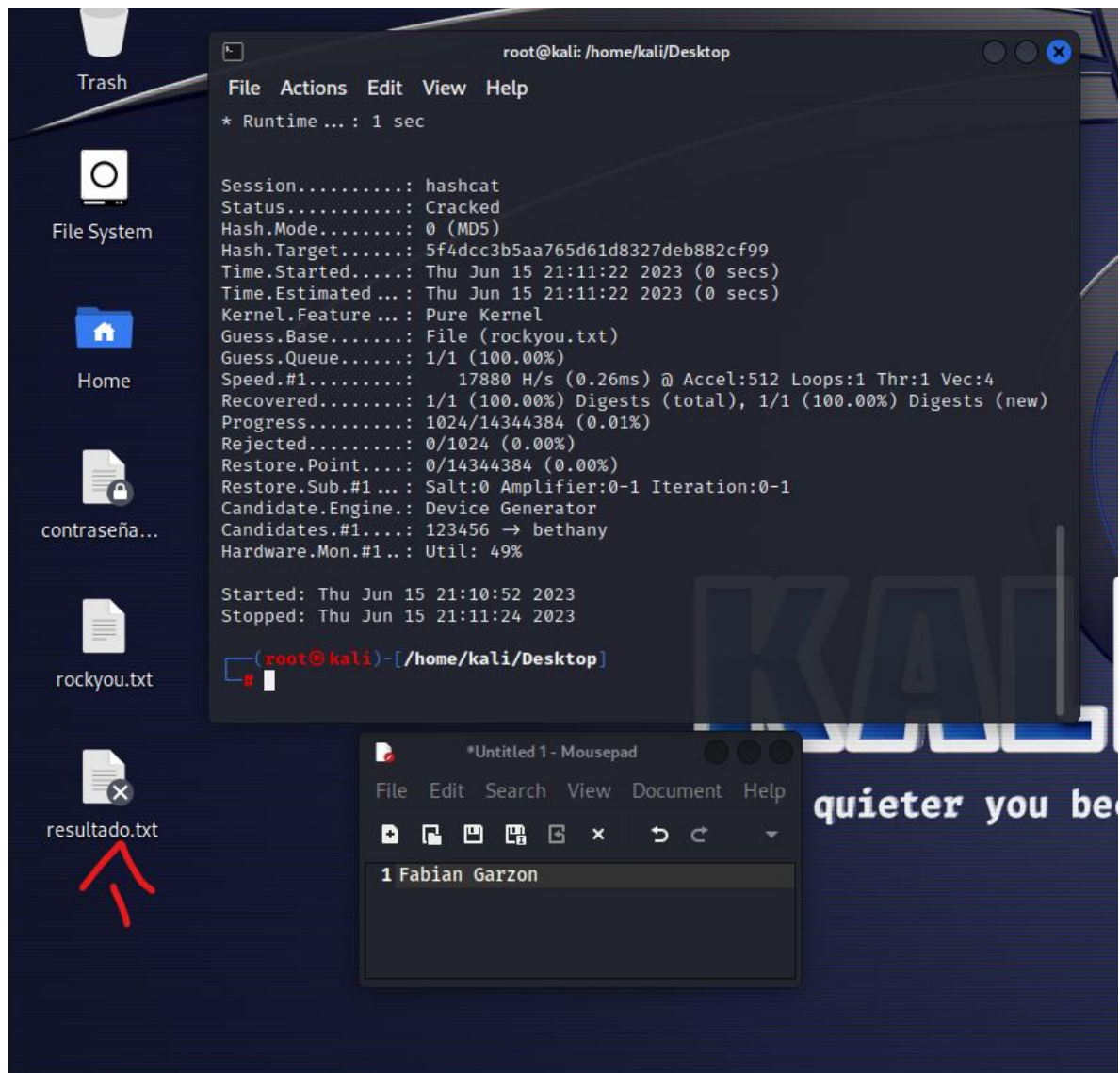


Imagen 33. Archivo resultado.txt creado

Se realiza un comando cat resultado.txt para visualizar el contenido del documento creado.

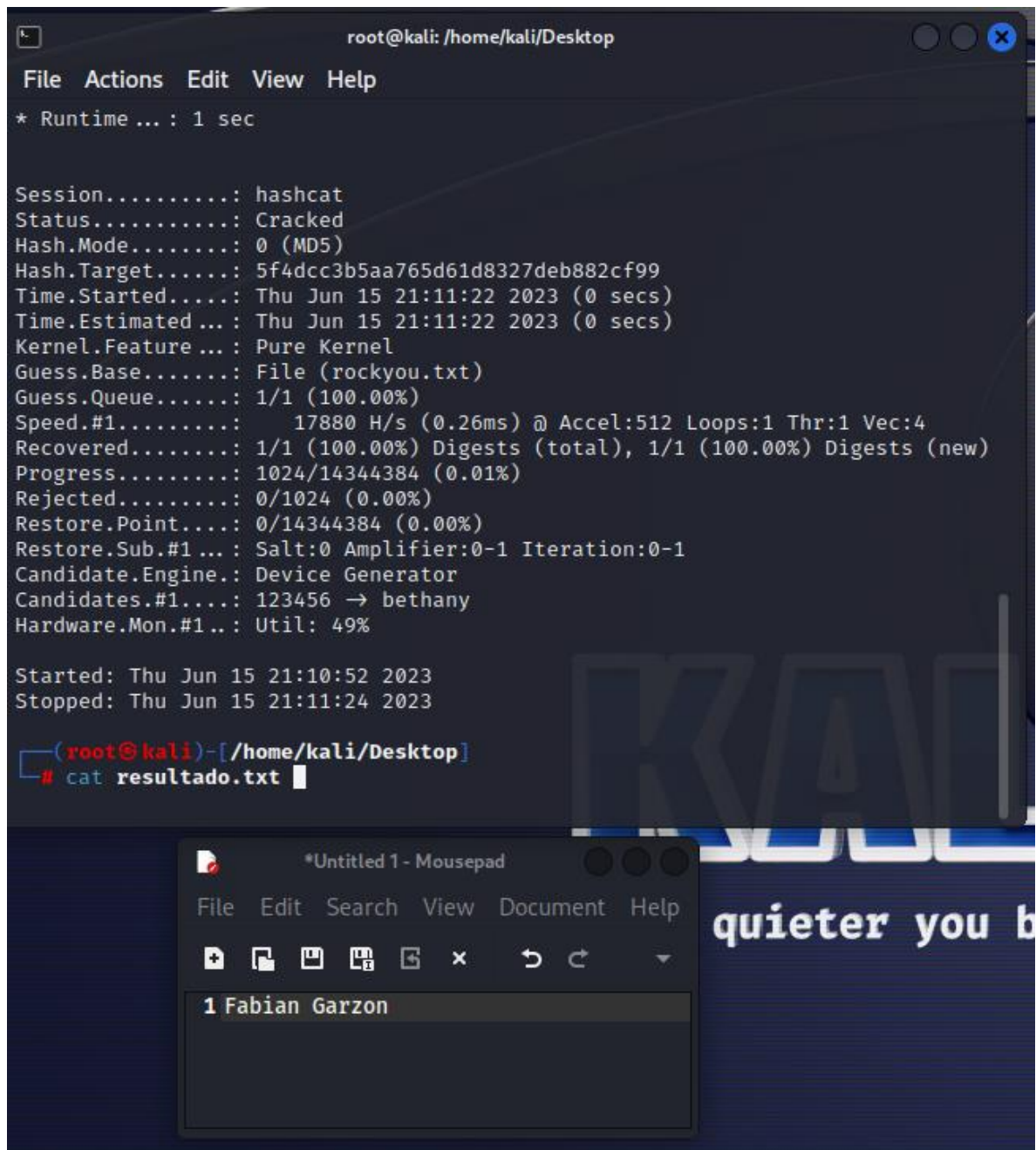
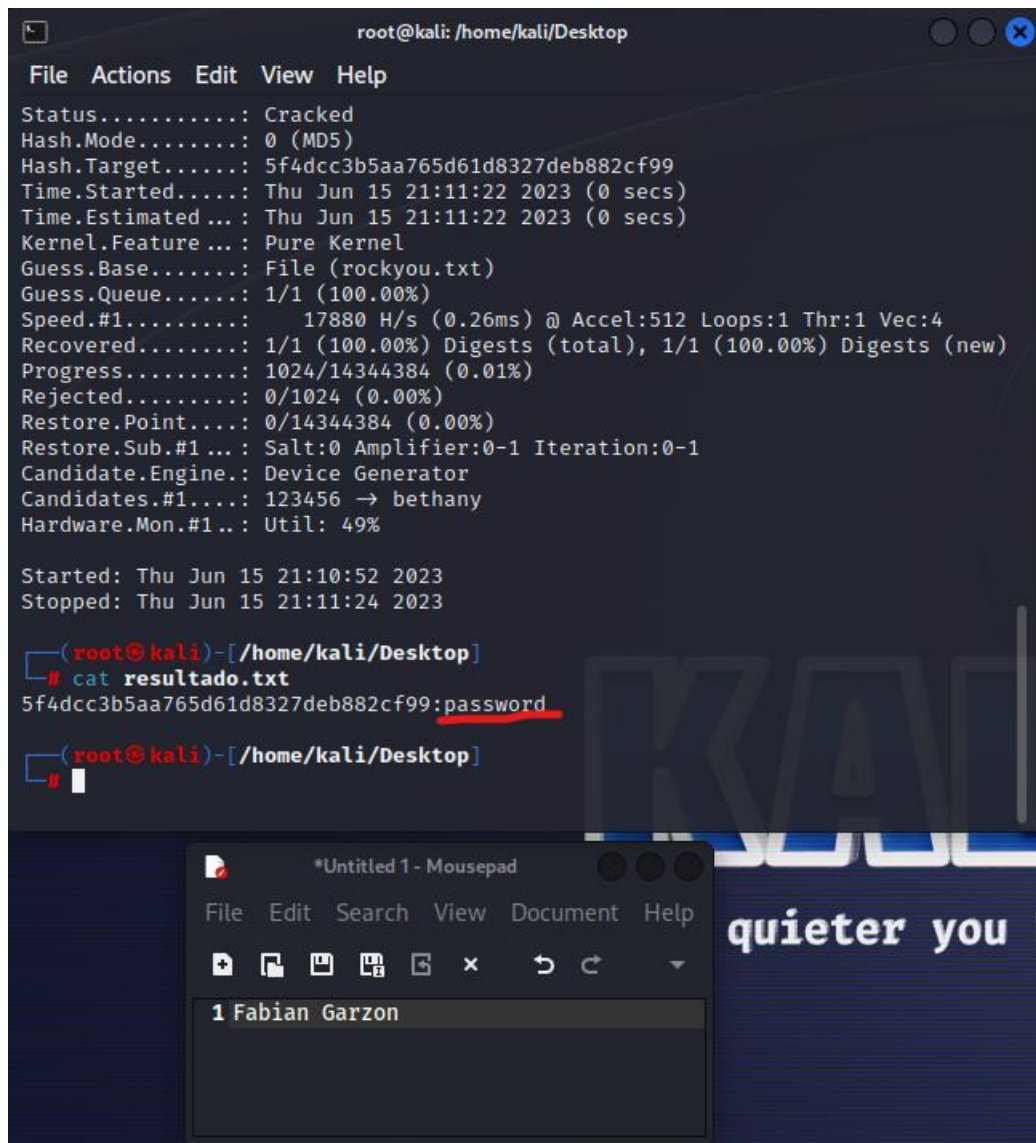


Imagen 34. Uso del comando cat resultado.txt

Para finalizar se visualiza el hash que insertamos y su respectiva contraseña en frente separada por dos puntos, en este caso se ve que coincide la palabra insertada en el emn178 que fue password.



```
root@kali: /home/kali/Desktop
File Actions Edit View Help
Status.....: Cracked
Hash.Mode.....: 0 (MD5)
Hash.Target.....: 5f4dcc3b5aa765d61d8327deb882cf99
Time.Started.....: Thu Jun 15 21:11:22 2023 (0 secs)
Time.Estimated...: Thu Jun 15 21:11:22 2023 (0 secs)
Kernel.Feature...: Pure Kernel
Guess.Base.....: File (rockyou.txt)
Guess.Queue.....: 1/1 (100.00%)
Speed.#1.....: 17880 H/s (0.26ms) @ Accel:512 Loops:1 Thr:1 Vec:4
Recovered.....: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.....: 1024/14344384 (0.01%)
Rejected.....: 0/1024 (0.00%)
Restore.Point...: 0/14344384 (0.00%)
Restore.Sub.#1...: Salt:0 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#1....: 123456 -> bethany
Hardware.Mon.#1..: Util: 49%

Started: Thu Jun 15 21:10:52 2023
Stopped: Thu Jun 15 21:11:24 2023

(root@kali)-[/home/kali/Desktop]
# cat resultado.txt
5f4dcc3b5aa765d61d8327deb882cf99:password

(root@kali)-[/home/kali/Desktop]
#
```

*Untitled 1 - Mousepad

File Edit Search View Document Help

1 Fabian Garzon

Imagen 35. Clave hasheada descifrada

Archivo en una web y SQLI

Archivos ocultos en sitio web

Para este laboratorio se va a hacer uso de dos máquinas virtuales, Kali Linux y Metasploitable, ejecutar el comando `cd /var/www`, luego `cd mutillidae`, y por último un `ifconfig` para revisar el direccionamiento IP del Metasploitable.

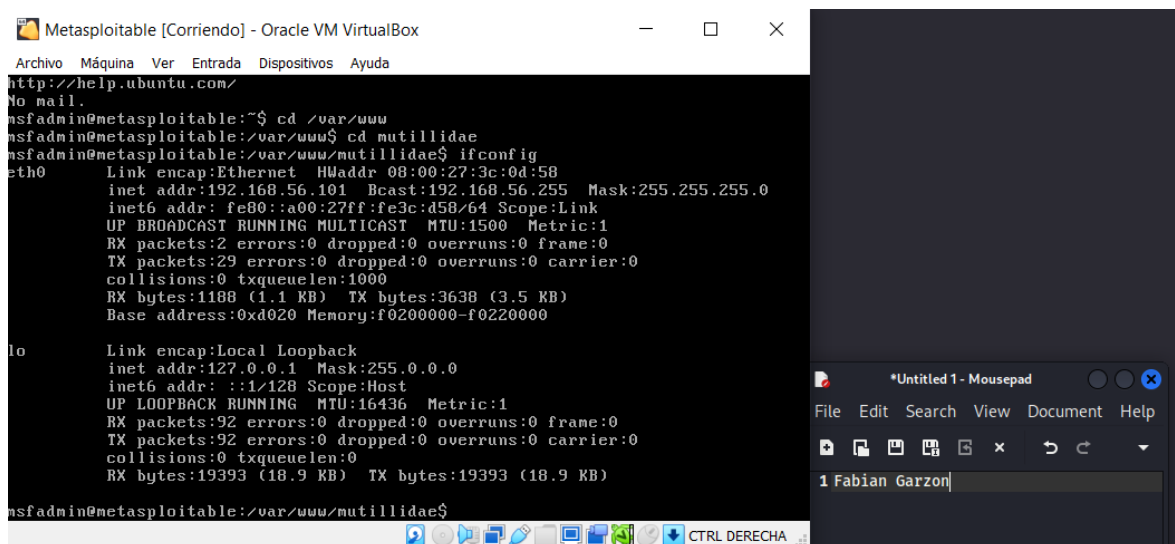


Imagen 36. Secuencia de comandos en Metasploitable

Teniendo el direccionamiento ip, accederemos a Kali Linux y se debe abrir una terminal y ejecutar el siguiente comando dirb <http://192.168.56.101/mutillidae>, en este caso el 192.168.56.101 es el direccionamiento ip que arrojó el Meta. El comando dirb se utiliza para buscar vulnerabilidades en la página a través de URL y puede haber información que comprometa la página o aplicativo web.

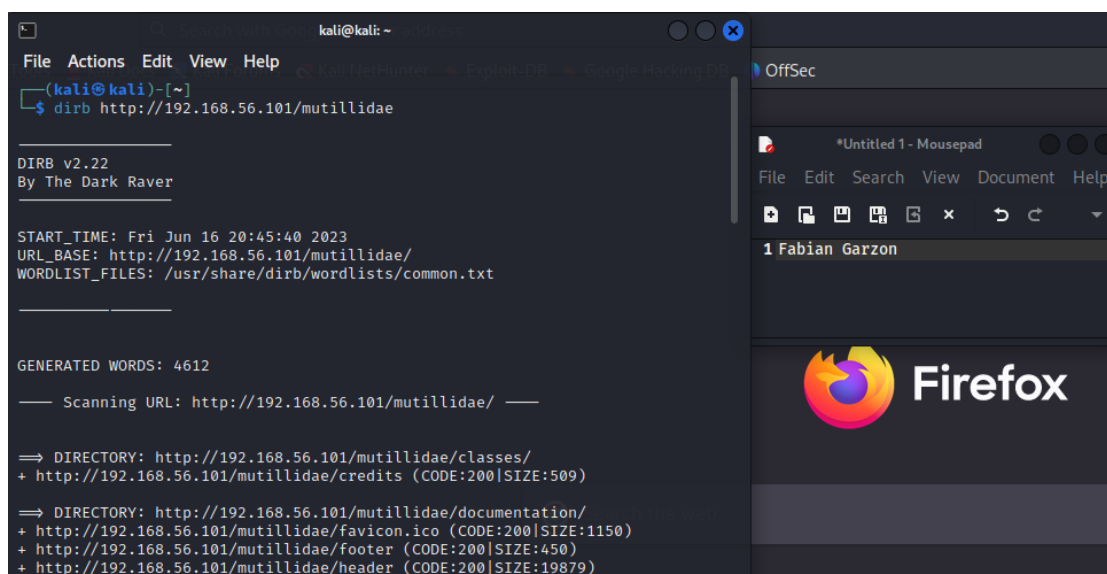


Imagen 37. Ejecución comando dirb

Dirigirse en la terminal al apartado de passwords, allí habrá un documento llamado robots.txt, abrir este enlace en el navegador.

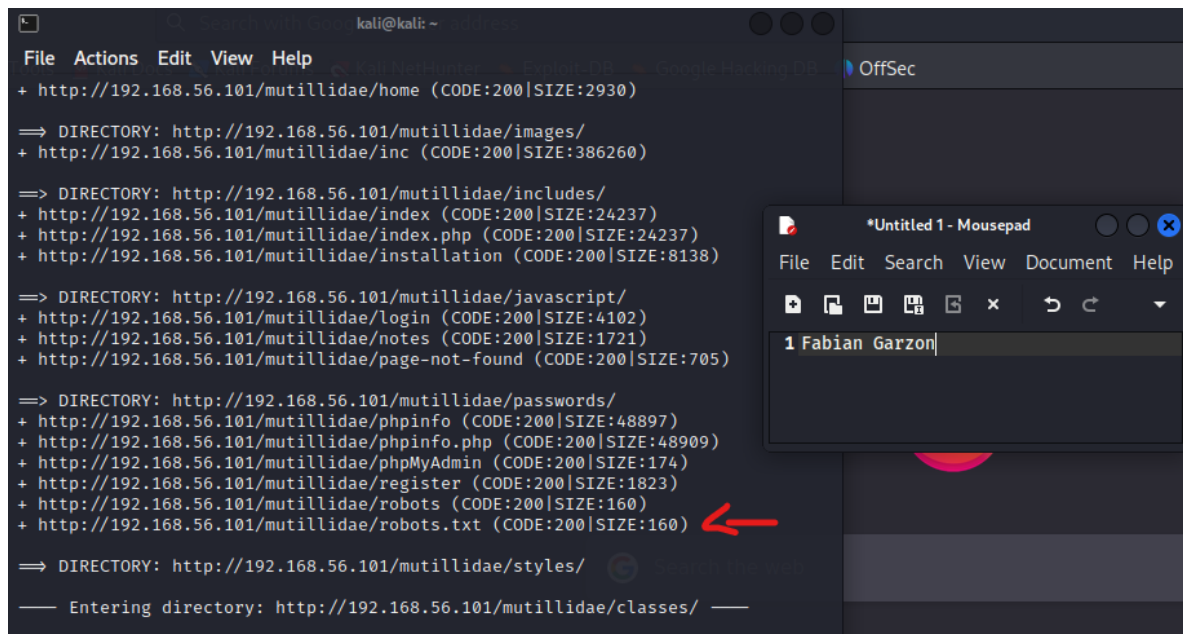


Imagen 38. Selección de robots.txt

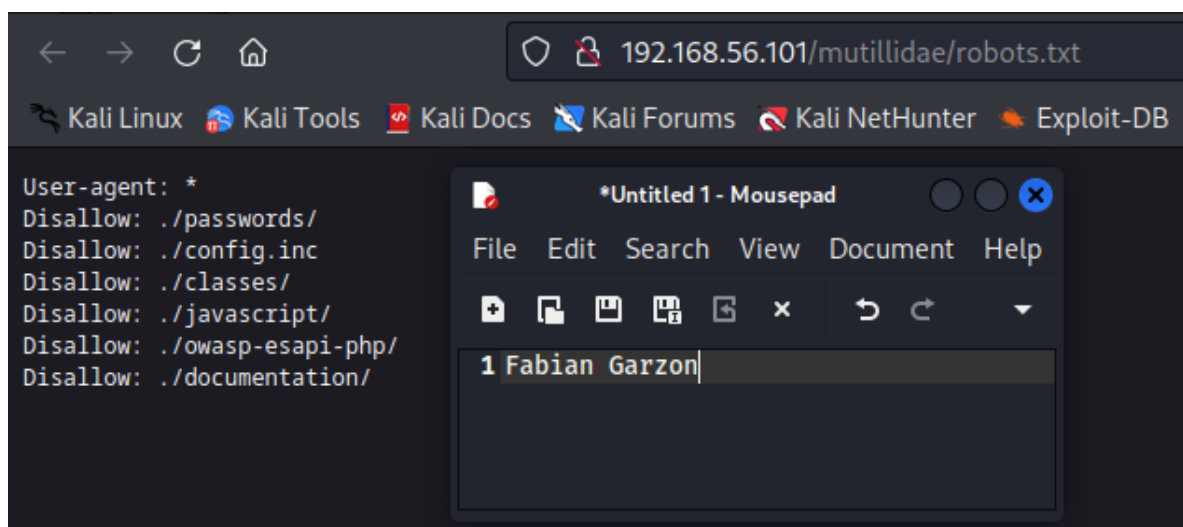


Imagen 39. Enlace abierto en el navegador

Ahora abrir el enlace que dice únicamente passwords, posteriormente dar clic en accounts.txt, allí encontraremos usuarios y sus respectivas contraseñas.

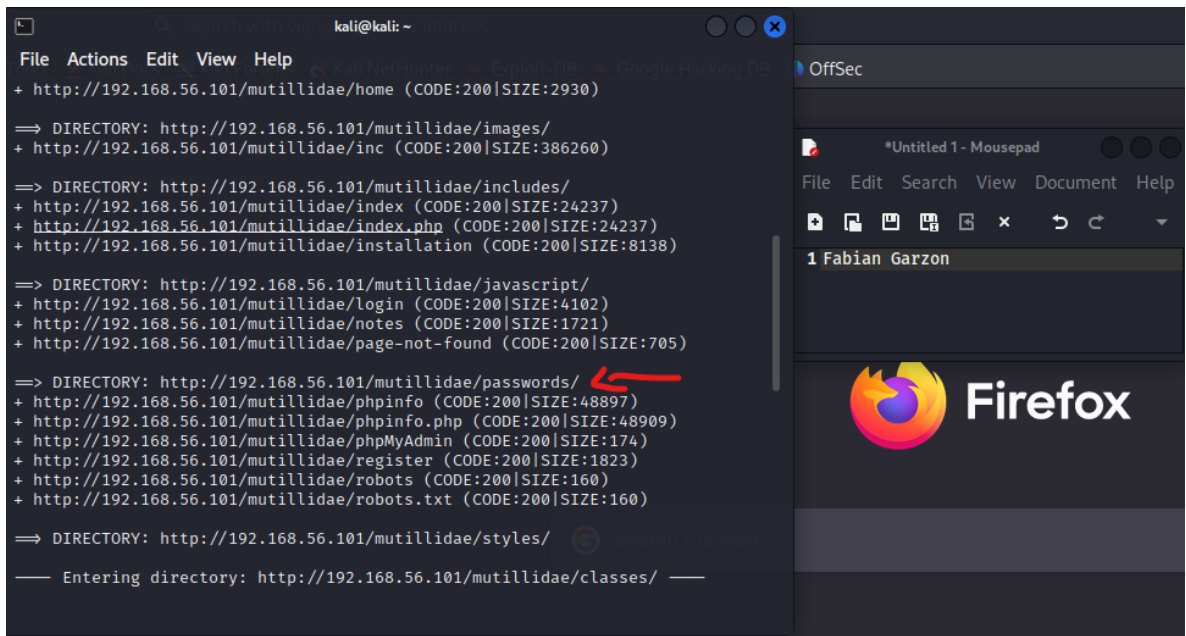


Imagen 40. Selección de passwords

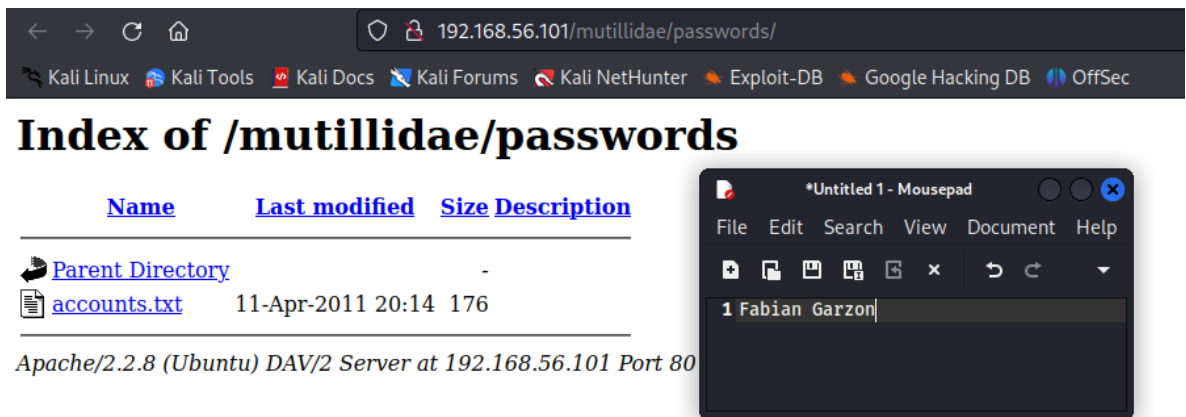


Imagen 41. Enlace abierto en el navegador

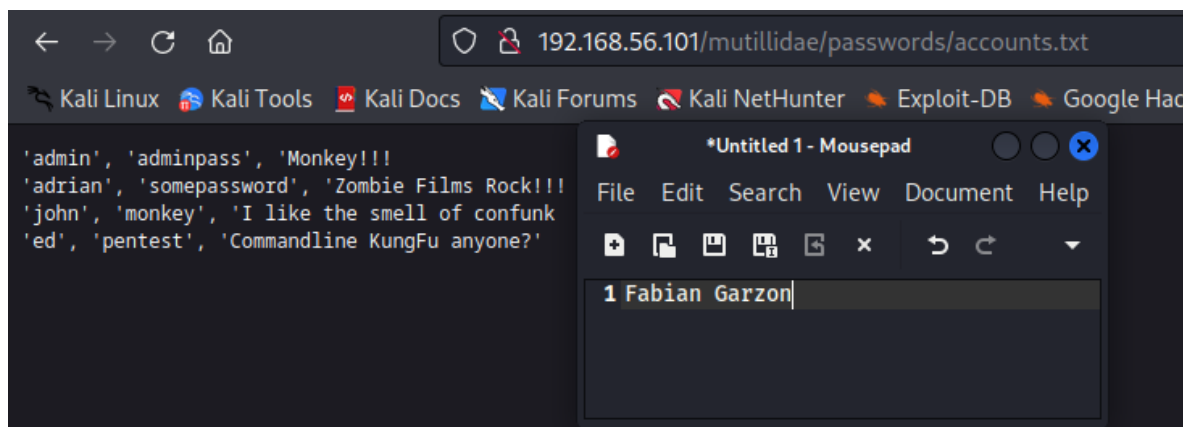


Imagen 42. Cuentas que se muestran en accounts.txt

SQL Injection en POST

En Metasploit escribir el siguiente comando `sudo nano /var/www/mutillidae/config.inc`, este comando abrirá un documento txt, en el cual se debe modificar el apartado `$dbname`, por defecto viene escrito `mutillidae`, así que se debe cambiar a `owasp10` y guardar.

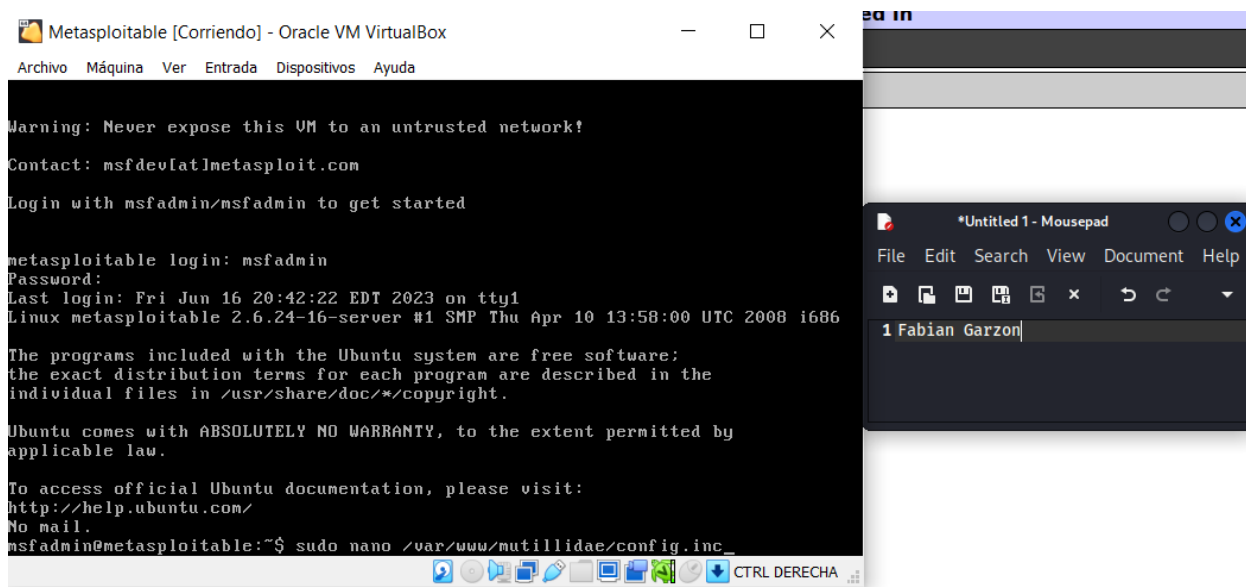


Imagen 43. Ejecución del comando

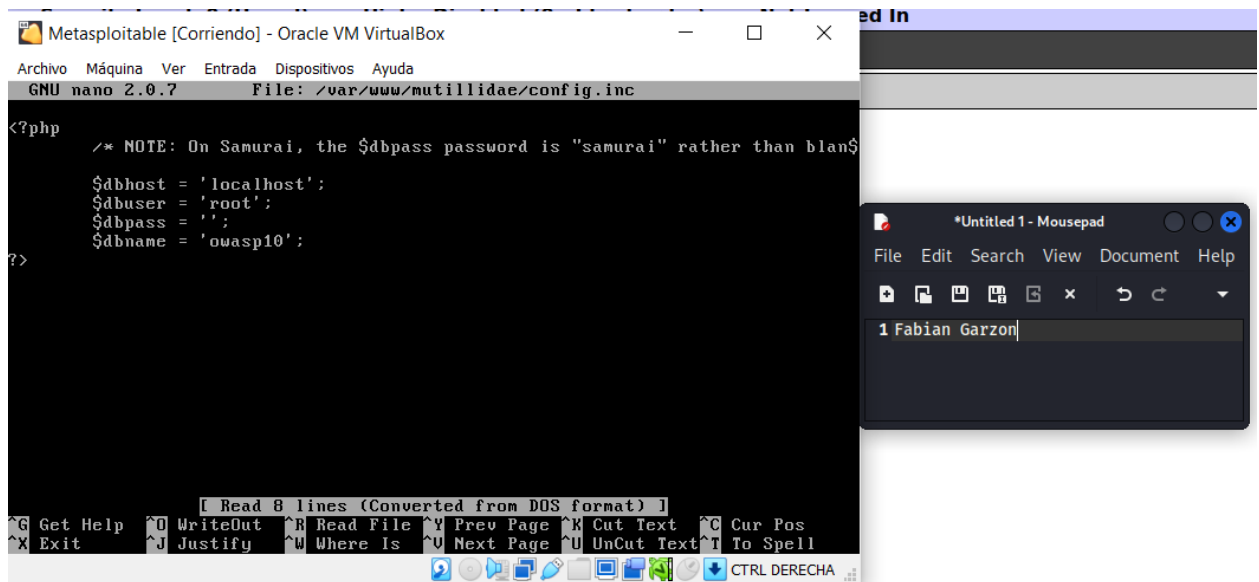


Imagen 44. Modificación de \$dbname

Ahora ingresar a la interfaz gráfica del mutillidae, para ello escribir en el navegador la dirección del Meta y mutillidae, de este modo 192.158.56.101/mutillidae.

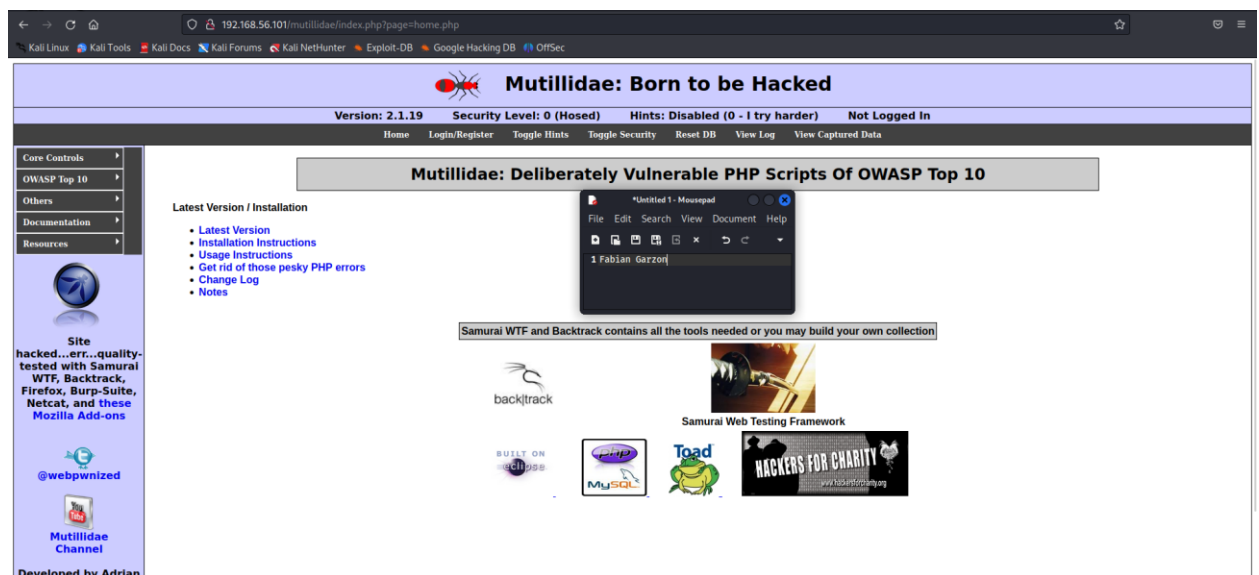


Imagen 45. Interfaz gráfica mutillidae

Ir al apartado de login/register y crear una cuenta, en este caso se creará la cuenta “prueba” y la respectiva contraseña es “prueba”.

Please choose your username, password and signature

Username

Password

Confirm Password

Signature

*Untitled 1 - Mousepad

File Edit Search View Document Help

1 Fabian Garzon

Create Account

Imagen 46. Creación de cuenta prueba

Ahora ir al login y colocar una comilla sencilla en el name, al hacer esto la página mostrará una serie de errores y a través de ellos vamos a intentar ingresar al sitio.

Login

Please sign-in

Name

Password

Login

Dont have an account? [Please register here](#)

*Untitled 1 - Mousepad

File Edit Search View Document Help

1 Fabian Garzon

Imagen 47. Comilla sencilla en Name

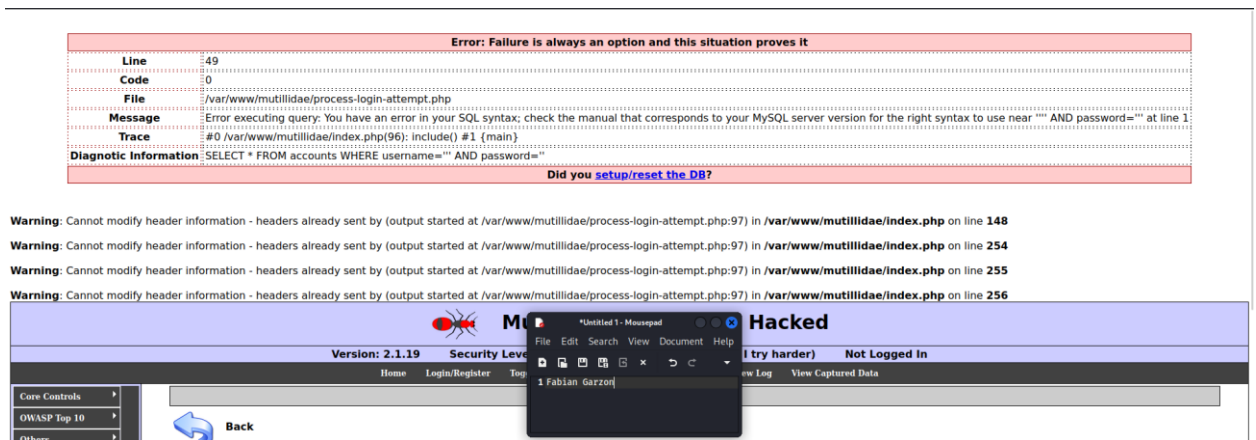


Imagen 48. Errores al ingresar con la comilla sencilla

Ingresar la siguiente línea en el apartado de password prueba' and 1=1#.

The image shows a login form with a green header that says "Please sign-in". Below the header, there are two input fields: "Name" and "Password". The "Name" field contains the text "prueba". The "Password" field contains the text "prueba' and 1=1#". Below the input fields, there is a blue button that says "Login". At the bottom of the form, there is a link that says "Dont have an account? Please register here". In the foreground, there is a blue notification box that says "Hacked" and a text input field containing "1 Fabian Garzon".

Imagen 49. Línea de código en password

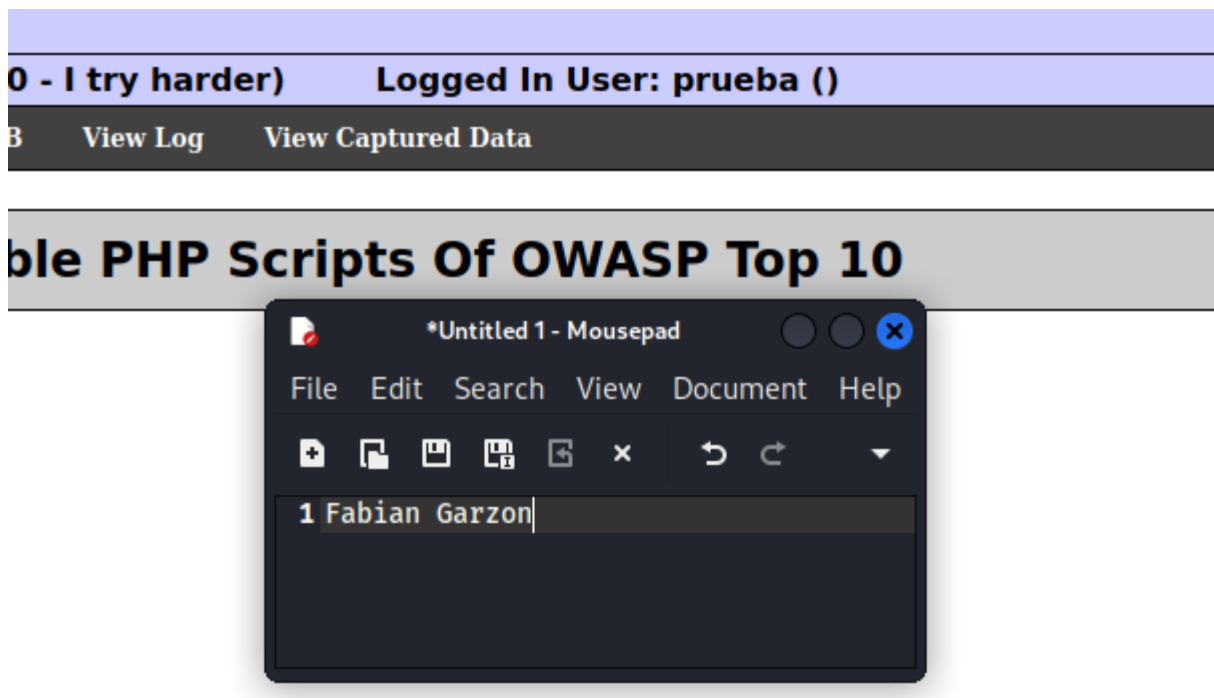


Imagen 50. Ingreso al usuario

Ahora se va a realizar la misma prueba, pero cambiando el 1 por un 2, de este modo prueba' and 1=2#.

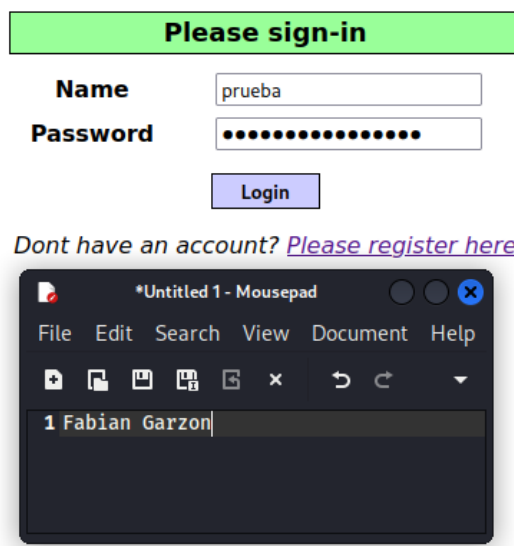


Imagen 51. Línea de código en password

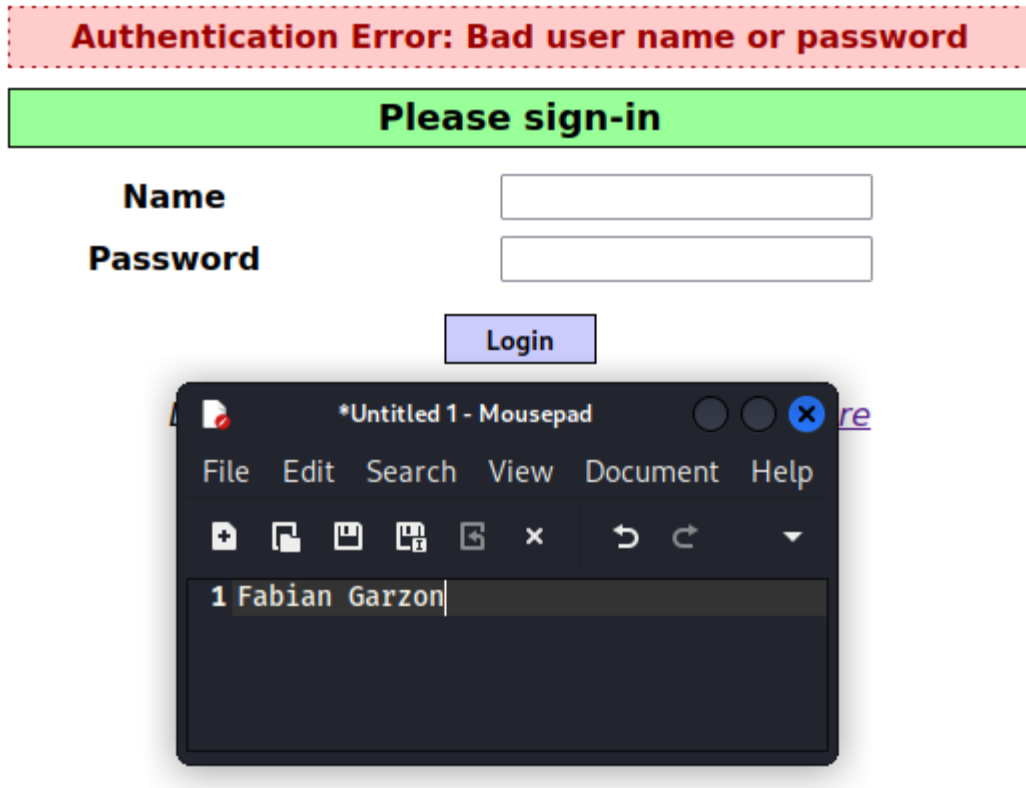


Imagen 52. Error al ingresar esa línea de código

Ahora vamos a intentar ingresar al usuario admin, para ello se coloca en Name admin, y en password la siguiente línea de código `aaa' or 1=1#`.

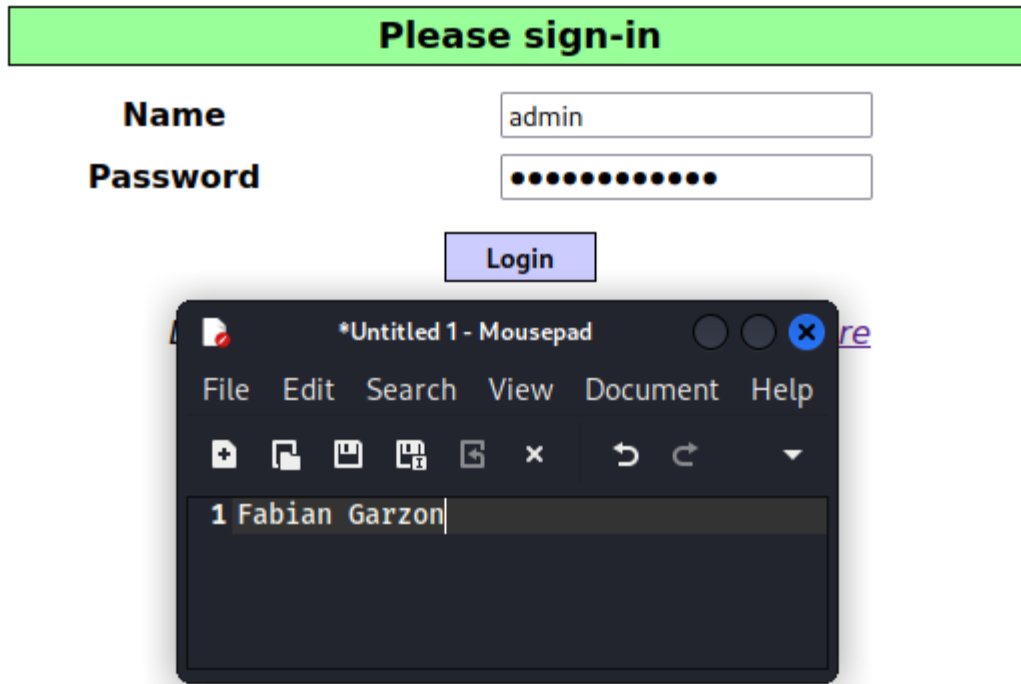


Imagen 53. Ingreso al usuario admin

Al dar clic en login se dará acceso a un usuario administrador con el nombre “Monkey!”.

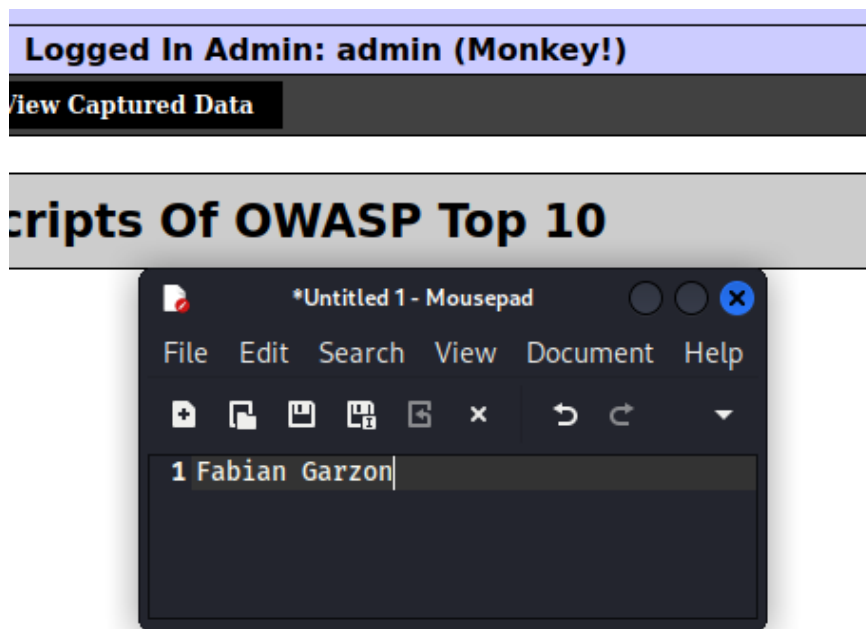
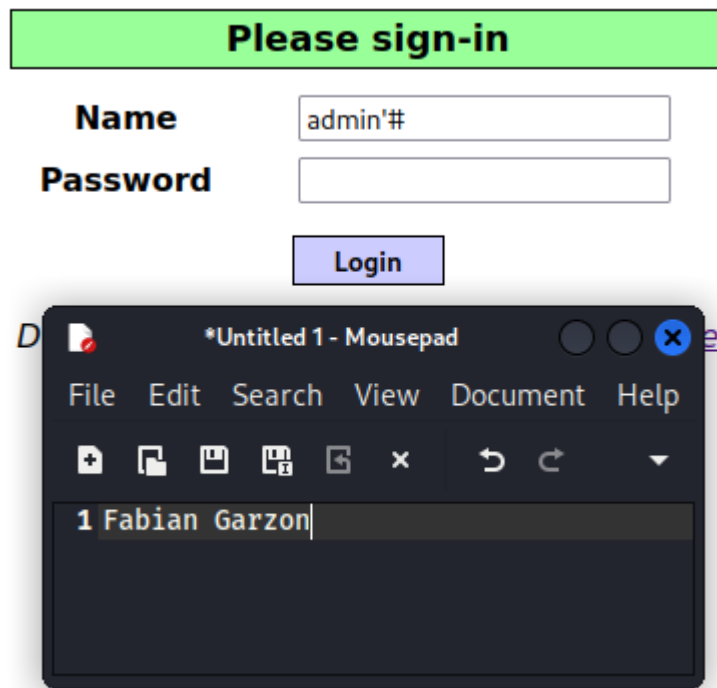


Imagen 54. Usuario logueado como admin

Ahora ingresar únicamente colocando un Name y colocando la siguiente línea admin'#.



Please sign-in

Name

Password

Login

Mousepad window: *Untitled 1 - Mousepad
File Edit Search View Document Help
1 Fabian Garzon

Imagen 55. Ingreso de usuario con solo Name

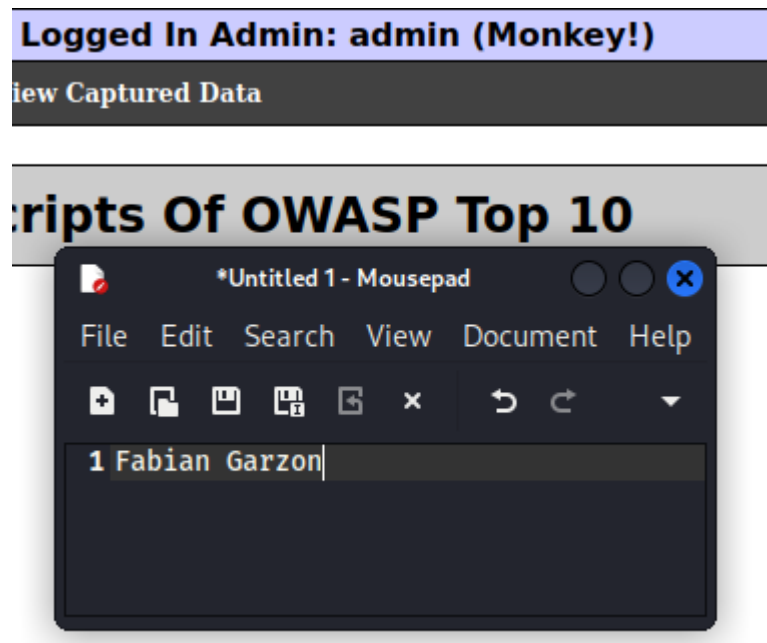


Imagen 56. Usuario logueado como admin

Ahora se va a modificar la seguridad de la página de 0 a 1, y para probar insertar la comilla sencilla en el Name.

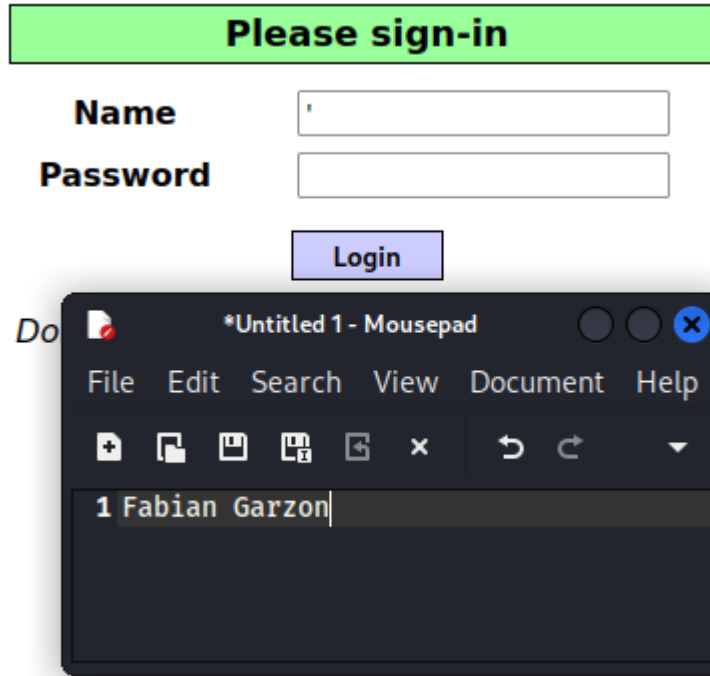


Imagen 57. Intento de acceso mediante comilla sencilla

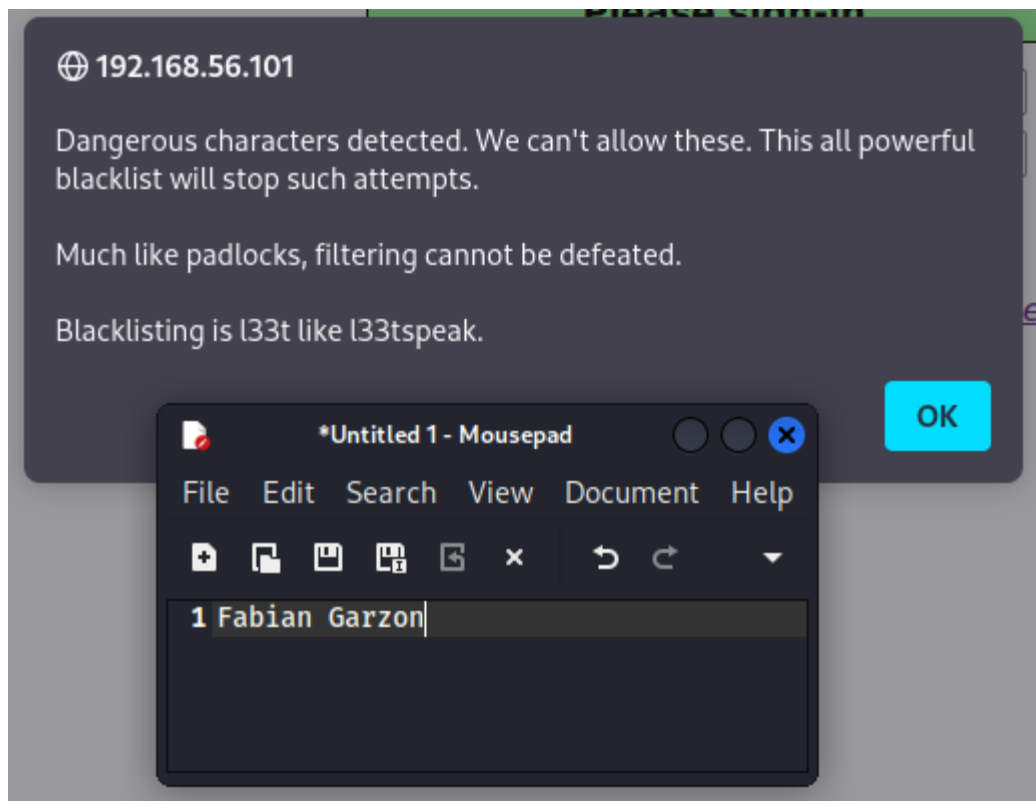


Imagen 58. Cuadro de texto que arroja la página

Para poder ingresar y ver si existe un filtro al cliente, se abre burpsuite y se activa el proxy del navegador. Para esta prueba se ingresará de Name admin y de password qwerty, al hacer esto verificar en el burpsuite la intercepción de los datos y dar clic en forward, este no va a responder.

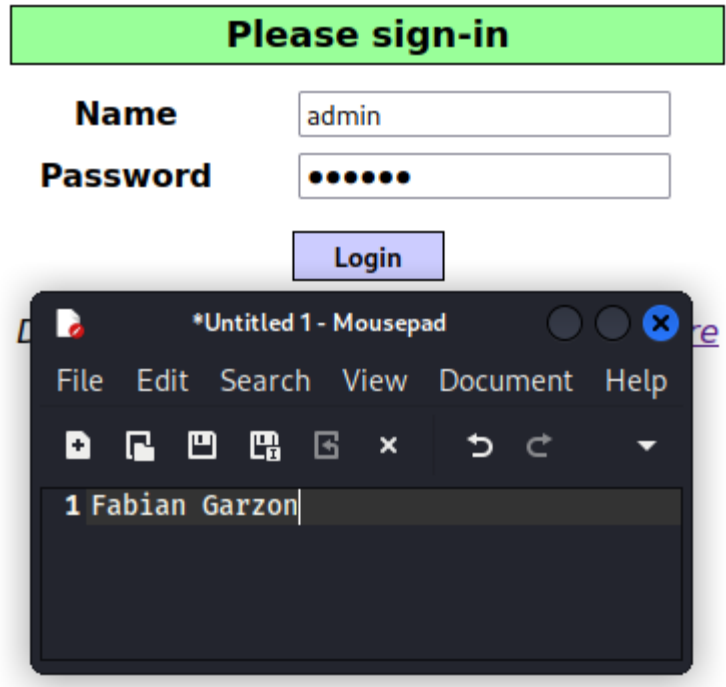


Imagen 59. Intento de ingreso con admin y contraseña qwerty

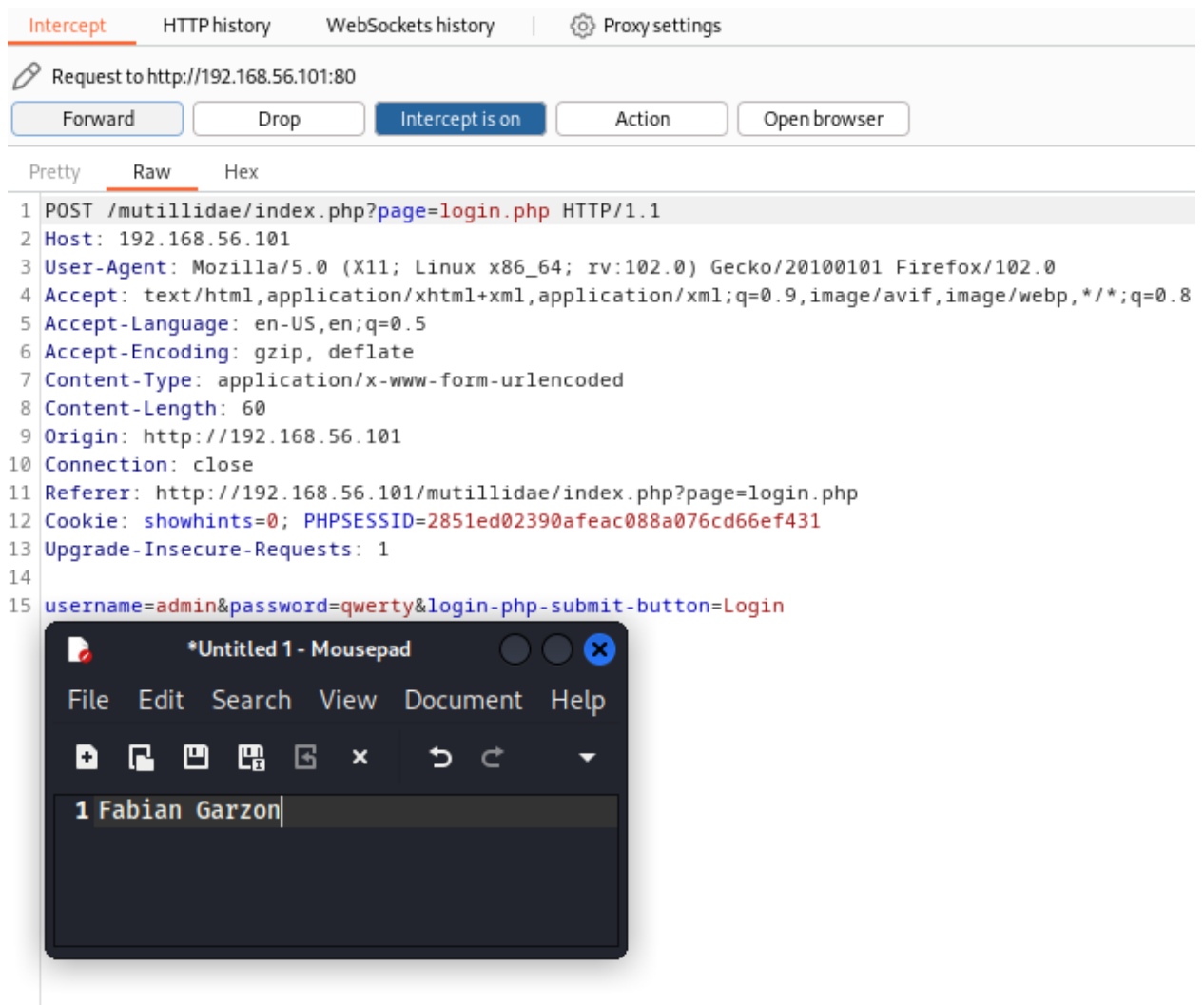


Imagen 60. Datos capturados en burpsuite

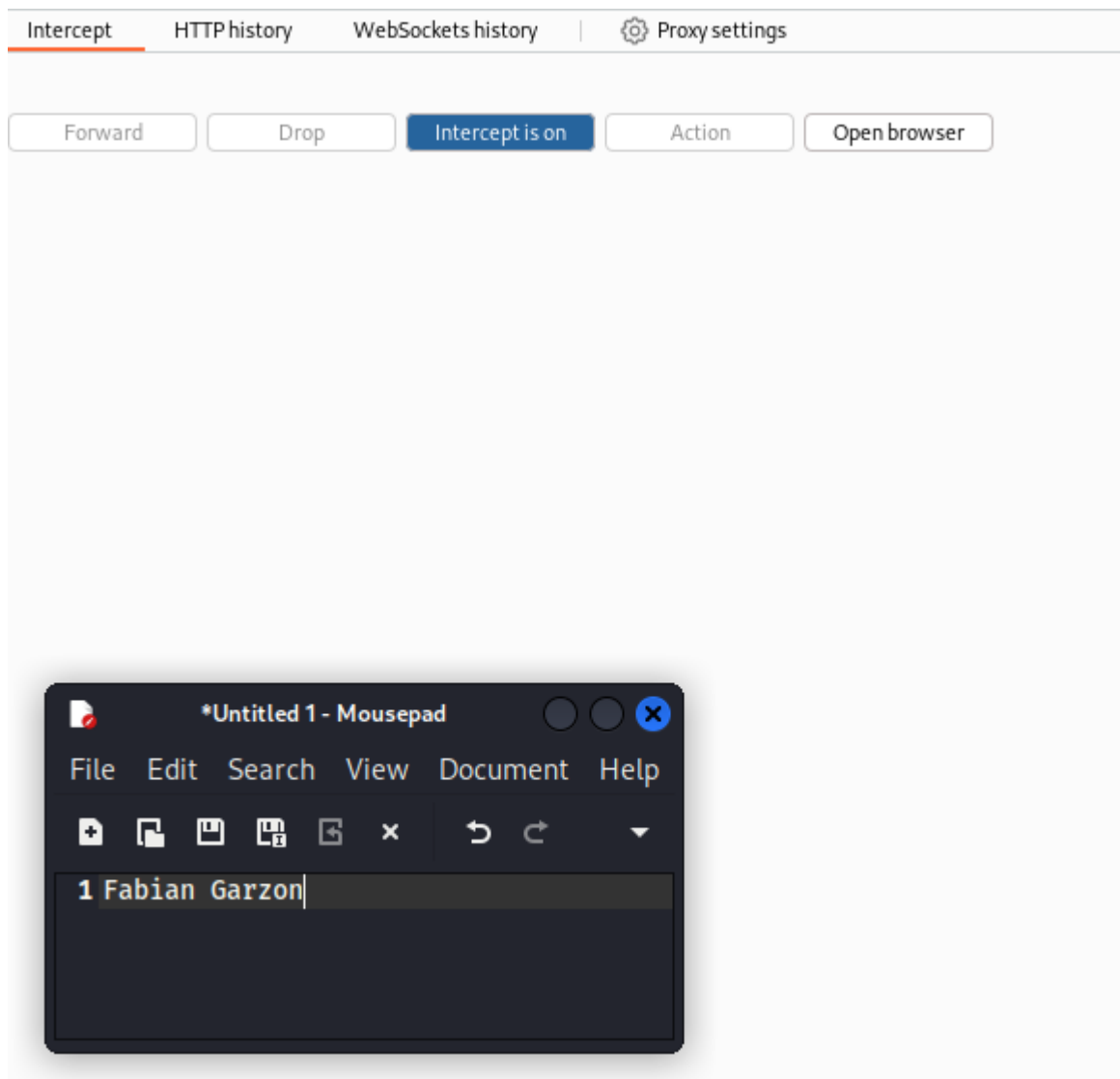


Imagen 61. Burpsuite después de dar clic en forward

Ahora para poder ingresar se van a realizar los mismos pasos mencionados anteriormente, pero esta vez se va a modificar en el burpsuite un apartado, esto dará el acceso y podremos ingresar al sistema.

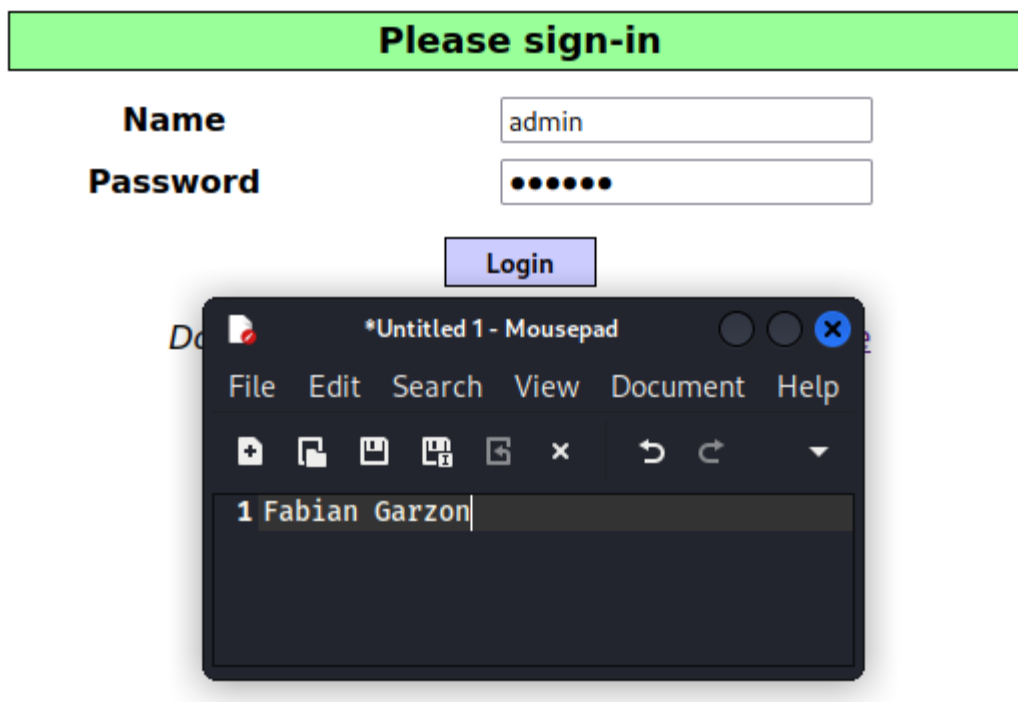


Imagen 62. Intento de ingreso con admin y contraseña qwerty

En el burpsuite después de capturar los datos desplegar el menú del inspector que dice request body parameters y modificar el username de admin a admin'#

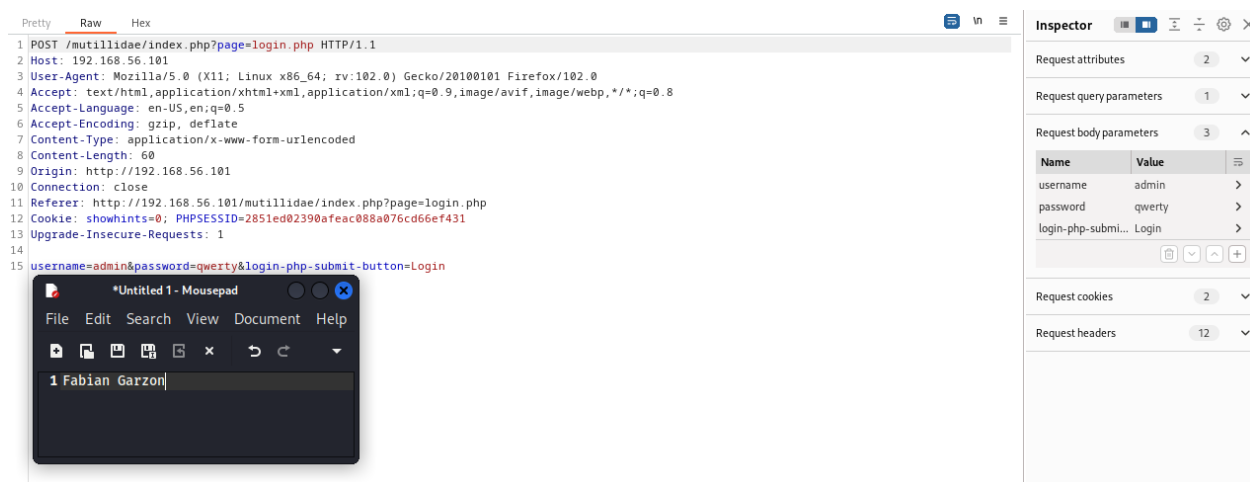


Imagen 63. Captura de burpsuite

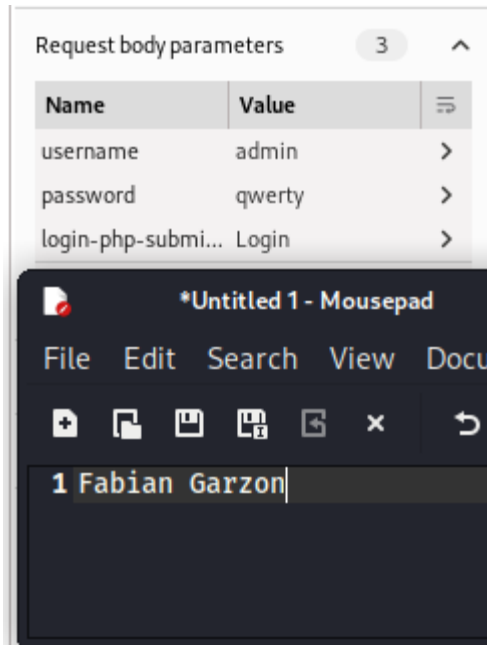


Imagen 64. Modificar username

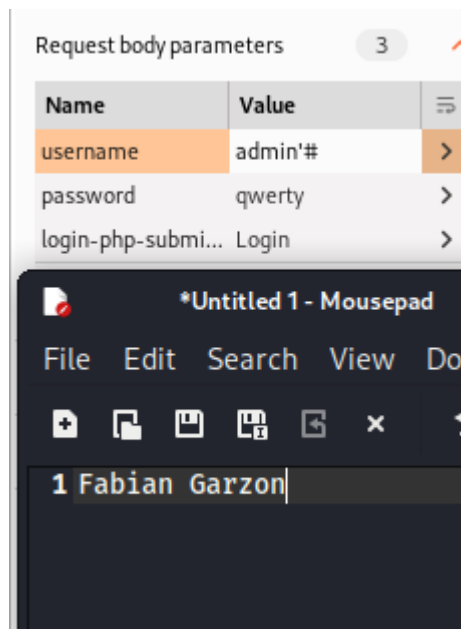


Imagen 65. Modificación hecha

Por último, dar clic en forward y en el navegador se verá que se ingresó correctamente al sistema.

Security Level: 1 (Arrogent)Hints: Disabled (0 - I try harder)Logged In Admin: admin (Monkey!)

HomeLogoutToggle SecurityReset DBView LogView Captured Data

Mutillidae: Deliberately Vulnerable PHP Scripts Of OWASP Top 10

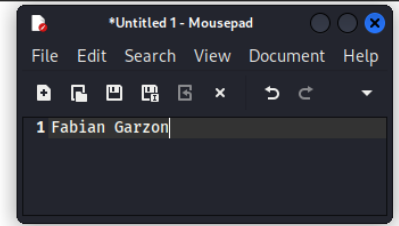


Imagen 66. Ingreso al sistema con seguridad media

Conclusiones

- Al explotar la vulnerabilidad Insecure direct object references se pueden tener consecuencias graves, como la exposición de datos personales o confidenciales, la modificación o eliminación de información sensible y la violación a la privacidad de los usuarios.
- Al utilizar métodos de cifrado muy antiguos es sencillo poder descifrarla, ya que no se requiere de una máquina demasiado potente y se necesitan muy pocas líneas de código para lograrlo, al ser explotada se pueden obtener contraseñas de cualquier cuenta, poniendo en peligro la información de los usuarios.
- Usar SQL Injection en un sitio con baja seguridad es muy sencillo, ya que únicamente requiere utilizar métodos OR o AND, para ingresar a usuarios admin se utilizan una comilla sencilla o un #, esto es peligroso ya que un usuario administrador cuenta con todo tipo de información sensible y puede ser peor si existen usuarios ingresados en las bases de datos. Al hacerlo en una página con una seguridad media lleva un poco más de tiempo pero sigue siendo sencillo, por ello es importante tener una seguridad demasiado alta en un aplicativo web y garantizar la seguridad de la información de los usuarios.